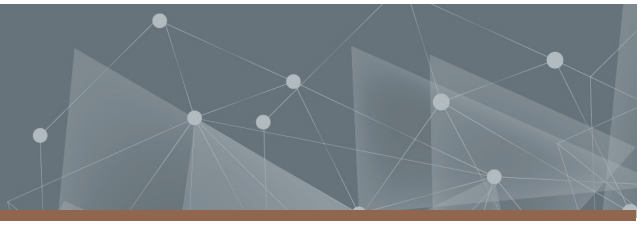


CHALMERS
UNIVERSITY OF TECHNOLOGY



Security Risks of Crafting Allowlists for Phishing Awareness and Simulated Attacks

An Experimental Threat Analysis of Trust Abuse in Enterprise Email Security

Master's thesis in Computer Systems and Networks

Anas Masri & Venkata Sai Sarat Chandra Yellapragada

DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING

CHALMERS UNIVERSITY OF TECHNOLOGY
Gothenburg, Sweden 2026
www.chalmers.se

Master's thesis 2026

Security Risks of Crafting Allowlists for Phishing Awareness and Simulated Attacks

An Experimental Threat Analysis of Trust Abuse in Enterprise Email Security

Anas Masri

Venkata Sai Sarat Chandra Yellapragada



CHALMERS
UNIVERSITY OF TECHNOLOGY

DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING
Division of Computer Systems and Networks
Chalmers University of Technology
Gothenburg, Sweden 2026

Security Risks of Crafting Allowlists for Phishing Awareness and Simulated Attacks
An Experimental Threat Analysis of Trust Abuse in Enterprise Email Security
Anas Masri, Venkata Sai Sarat Chandra Yellapragada

© Anas Masri, Venkata Sai Sarat Chandra Yellapragada 2026.

Supervisor: Victor Morel, Department of Computer Systems and Networks
Co-Supervisor: Xiuqi Zhang, Department of Computer Systems and Networks
Examiner: Risat Pathan, Department of Computer Systems and Networks

Master's Thesis 2026
Department of Computer Systems and Networks
Chalmers University of Technology
SE-412 96 Gothenburg
Telephone +46 31 772 1000

Typeset in LaTeX
Printed by Chalmers Reproservice
Gothenburg, Sweden 2026

Security Risks of Crafting Allowlists for Phishing Awareness and Simulated Attacks
An Experimental Threat Analysis of Trust Abuse in Enterprise Email Security
Anas Masri, Venkata Sai Sarat Chandra Yellapragada
DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING
Chalmers University of Technology

Abstract

Phishing continues to be one of the most widespread and effective attack techniques used against organizations. To reduce this risk, many companies rely on Security Awareness Training (SAT) platforms that send controlled phishing simulations to employees. Since these simulations are designed to look like real attacks, they can be flagged by the same filtering logic used to stop malicious or spam email. To ensure the messages are delivered, organizations commonly allowlist vendor IP ranges, sending domains, or custom simulation headers. While these configurations make the training function properly, they also introduce trusted paths that attackers may be able to exploit.

This thesis investigates the security implications of the allowlisting mechanisms used in phishing awareness training. The central question is whether typical allowlist configurations can be abused to bypass enterprise email filtering. The analysis focuses on three areas: spoofable simulation headers, shared sending infrastructure, and vendor-related domain exposure. Experiments were conducted in a Microsoft 365 sandbox using phishing-like, spam-like, benign, and European Institute for Computer Antivirus Research (EICAR)-based test payloads. Publicly available information about vendor domains and allowlisting recommendations from major SAT providers was also reviewed.

The results show that header-based allowlisting can introduce a clear bypass risk when a custom header—such as `X-PHISHTEST`—is treated as a primary trust indicator. In the tested environment, any message containing the expected header was delivered to the Inbox, even when the content resembled phishing or spam. This demonstrates how weak unauthenticated headers are as signals of legitimacy. The experiments also reveal that IP-based allowlisting on shared infrastructure can unintentionally extend trust to unrelated tenants. When a shared SendGrid IP range (a cloud-based email delivery platform with shared sending infrastructure) was allowlisted, both the intended vendor and an unrelated sender using the same infrastructure were able to deliver non-malware payloads to the Inbox. Malware samples, however, were consistently quarantined, suggesting that these bypasses mainly affected spam and phishing classification rather than malware detection.

The domain review did not identify any unregistered primary vendor domains, meaning no immediate takeover risk was observed. However, the analysis highlights the importance of careful domain lifecycle management. Outdated allowlist entries, expired domains, and campaign-specific domains can create long-term exposure if they are not actively maintained.

Keywords: phishing, security awareness training, allowlisting, Microsoft 365, email security, spoofing, SendGrid, SPF, DKIM, DMARC, transport rules

Acknowledgements

We would like to express our sincere gratitude to our supervisor, Victor Morel, and our co-supervisor, Xiuqi Zhang, for their guidance, feedback, and support throughout this thesis work. We would also like to thank our examiner, Risat Pathan, for his time, evaluation, and valuable academic input.
Finally, we are deeply grateful to our families for their continuous encouragement, patience, and support during our studies and throughout the completion of this thesis.

Anas Masri, Venkata Sai Sarat Chandra Yellapragada, Gothenburg, June 2026

AI Tool Disclosure

During the preparation of this thesis, AI-based writing tools were used to support language refinement, grammar correction, restructuring of selected paragraphs, and improvement of clarity. The authors remained responsible for the research design, experiments, analysis, interpretation of results, and final written content. No AI tool was used as an independent source of empirical data or as a substitute for the authors' academic judgment.

List of Acronyms

BEC Business Email Compromise. 17

DKIM DomainKeys Identified Mail. 5, 6, 8, 13, 14, 15, 16, 18, 28, 29, 32, 45, 46, 50, 54, 57
DMARC Domain-based Message Authentication, Reporting, and Conformance. 5, 6, 8, 13, 14, 15, 16, 18, 28, 29, 32, 45
DNS Domain Name System. 6, 22, 24, 28

EICAR European Institute for Computer Antivirus Research. v, 26, 49, 51, 52, 53, 54, 55
ETR Exchange Transport Rule. 7, 8, 15, 25, 28, 32, 33, 45

ML Machine Learning. 1
MTA Mail Transfer Agent. 5, 14, 15
MX Mail Exchange Record. 31, 44

NLP Natural Language Processing. 1

SAT Security Awareness Training. v, 1, 2, 3, 5, 7, 8, 9, 11, 12, 13, 14, 16, 17, 18, 28, 33, 43, 44, 45, 46, 47, 48, 49, 50, 51, 52, 53, 54, 55, 56, 57, 58
SCL Spam Confidence Level. 7, 8, 28, 29, 32, 45, 49, 50
SEG Secure Email Gateway. 7
SMTP Simple Mail Transfer Protocol. 5, 6, 14, 17, 25, 27
SPF Sender Policy Framework. 5, 6, 8, 13, 14, 15, 16, 17, 18, 28, 29, 32, 45

URL Uniform Resource Locator. 13, 17

WHOIS WHOIS Registration Data Protocol. 22, 28, 29

Contents

AI Tool Disclosure **ix**

List of Acronyms **x**

Nomenclature **xiii**

List of Figures **xv**

List of Tables **xvii**

1 Introduction **1**
1.1 Scope . . . 3
1.2 Thesis outline . . . 4

2 Background **5**
2.1 Email Identity and Sender Fields . . . 5
2.2 Email Authentication Protocols . . . 6
2.3 Email Security and Phishing Defense . . . 7
2.4 Allowlisting . . . 7
2.5 Security Awareness Training Platforms . . . 8

3 Related Work **11**
3.1 Phishing Attacks and Security Awareness Training . . . 11
3.2 Security implications of Allowlisting . . . 13
3.3 Vulnerabilities in Email Authentication Protocols . . . 14
3.4 Shared Cloud Infrastructure . . . 16
3.5 Necessity of Layered Email Defenses . . . 17
3.6 Summary . . . 19

4 Methods **21**
4.1 Threat Model . . . 21
4.2 Experimental Environments . . . 25
4.3 Payload Specification . . . 26
4.3.1 Payload Categories . . . 26
4.3.2 Content Format . . . 26
4.3.3 Indicator Injection . . . 27
4.4 Experimental Phases . . . 27

4.4.1 Phase 1: Baseline Establishment . . . 27
4.4.2 Phase 2: Header Spoofing . . . 28
4.4.3 Phase 3: Shared Infrastructure Abuse . . . 28
4.4.4 Phase 4: Domain Analysis . . . 28
4.4.5 Phase 5: Production Validation . . . 29
4.5 Data Collection and Analysis . . . 29

5 Results **31**
5.1 Phase 1: Baseline Establishment . . . 31
5.2 Phase 2: Header Spoofing . . . 32
5.3 Phase 3: Shared Infrastructure Abuse . . . 33
5.4 Phase 4: Domain Analysis . . . 34
5.4.1 knowBe4 . . . 34
5.4.2 Cofense . . . 35
5.4.3 Microsoft (Attack Simulation Training) . . . 36
5.4.4 Proofpoint . . . 37
5.4.5 Hoxhunt . . . 38
5.4.6 Infosec IQ . . . 39
5.4.7 Barracuda . . . 40
5.5 RS4: Real-World Environment . . . 41
5.5.1 Using GoPhish . . . 42
5.5.2 Using Swaks . . . 42

6 Discussion **43**
6.1 Interpretation of the Baseline Results . . . 43
6.2 Header-Based Allowlisting and RQ1 . . . 44
6.3 Shared Infrastructure Abuse and RQ2 . . . 46
6.4 Domain Analysis and RQ3 . . . 47
6.5 The Real-World Sandbox Results . . . 48
6.6 Cross-Phase Interpretation . . . 49
6.7 Implications for Security Awareness Training . . . 50
6.8 Mitigation Strategies . . . 50
6.9 Ethics . . . 52
6.10 Limitations . . . 52
6.11 Future Work . . . 54

7 Conclusion **55**
7.1 Answers to the Research Questions . . . 55
7.2 Final Remarks . . . 58

Bibliography **59**

List of Figures

List of Tables

4.1 Threat model summarizing abuse methods, potential impact, and practical limitations across four allowlist-related threat categories. . . 23

5.1 Phase 1 baseline results using Swaks 31
5.2 Phase 1 baseline results using GoPhish 32
5.3 Phase 2 results after applying the `X-PHISHTEST` header-based transport rule 32
5.4 Phase 3 results using the authorized SendGrid account (`venkatac.dev`) 33
5.5 Phase 3 results using an unrelated SendGrid account (`anasmasri.xyz`) 34
5.6 KnowBe4 Domain Analysis 35
5.7 Cofense Domain Analysis 36
5.8 Microsoft Attack Simulation Training Domain Analysis 37
5.9 Proofpoint Security Awareness Training Domain Analysis 38
5.10 Hoxhunt Domain Analysis 39
5.11 Infosec IQ Domain Analysis 39
5.12 Barracuda Security Awareness Training Domain Analysis 40
5.13 RS4 results using GoPhish in the Chalmers mail environment 42
5.14 RS4 results using `Swaks` in the Chalmers mail environment 42

1
Introduction

Phishing attacks and social engineering are among the most widely exploited techniques in modern cybersecurity. Many organizations report data breaches, credential theft, and compromised business emails as a direct result of phishing campaigns [1]. As a response, organizations rely on SAT platforms to educate employees and evaluate their ability to recognize phishing attempts. These platforms run realistic phishing simulations, where employees receive controlled emails that imitate real-world attacks. These simulation campaigns are typically conducted during specific, scheduled periods, known as training windows, allowing organizations to test and improve readiness in a safe environment. SAT is now widely used and recommended for medium and large organizations [2].

For these simulated attacks to reach employee inboxes, organizations must reconfigure their email security filters by creating allowlists. An allowlist is an email security rule that explicitly permits emails from specific, trusted sources, such as the SAT vendor's IP addresses, domains, or custom headers, to bypass standard spam and malware filters. Without these configurations, simulated phishing emails would be blocked by the organization's existing security gateway designed to stop real attacks. This blockage occurs because these training emails intentionally mimic the structural and linguistic patterns of actual threats. To detect these patterns, modern email security tools rely on filtering techniques based on Machine Learning (ML) and Natural Language Processing (NLP). These systems use NLP to conduct context-aware classification of the email text to identify deceptive language and semantic cues [3].

While allowlists are necessary to ensure the simulations are delivered during an active campaign (the training window), the core problem addressed in this thesis is that these configurations introduce exploitable weaknesses into the organization's email security. An exploitable weakness refers to a structural flaw where the implicit trust granted to the SAT vendor can be hijacked by malicious actors. Because the filters are supposed to allow emails based on a specific rule, an external attacker who spoofs that rule can bypass the organization's defenses entirely. These rules are frequently left active indefinitely, meaning the organization remains vulnerable long after the actual training window has concluded.

This vulnerability is actively exploitable in production environments. In 2023, Vaisha Bernard, Chief Hacker at Eye Security, demonstrated that Microsoft's Attack Simulation Training platform deployed default phishing templates containing unregistered sending domains and links to non-existent cloud resources [4]. Bernard discovered this vulnerability while testing the simulation program to evaluate its potential use for Eye Security's customer portfolio. SAT vendors typically use these

placeholder domains in their templates to make the simulated emails look authentic, such as imitating a familiar brand name or an internal IT service, without directing users to actual malicious websites. However, a critical security vulnerability is created when a vendor includes these realistic-looking domains in their public templates but fails to register them. By simply registering these abandoned domains, Bernard successfully intercepted live email replies and access requests from employees worldwide who were participating in their organizations' simulation campaigns [4]. If an attacker had preemptively registered these domains, they could have leveraged the target organizations' existing allowlists to bypass email filtering entirely. Because the filters were configured to implicitly trust the simulation infrastructure, an attacker could have delivered a malicious payload, such as a document embedded with viruses, a credential-harvesting script, or an executable file designed to gather organizational data, directly to users' inboxes.

Despite the widespread use of allowlist configurations, the extent to which they increase the attack surface of the organization is often overlooked. To address this gap, this thesis investigates the exploitability of standard SAT allowlist configurations by demonstrating how attackers can abuse them to bypass spam filters and deliver malicious content. Based on this motivation, the thesis aims to answer the following research questions:

1. **RQ1: Can an attacker bypass enterprise spam filters by spoofing standard simulation headers such as `X-PHISHTEST`?**
   To ensure training emails reach users, SAT platforms often instruct IT teams to create a mail flow rule that bypasses spam filtering for any email containing a specific custom header, such as `X-PHISHTEST`. This header is used as a tag to identify authorized simulations. This question investigates whether an external attacker can exploit this rule by simply injecting the same header into a malicious email, using it to bypass security controls.
2. **RQ2: Can an attacker utilize a trial account on a major SAT platform to deliver malicious emails to organizations that have allowlisted that vendor's IP range?**
   Many SAT vendors use shared cloud email providers (such as SendGrid) to deliver their simulations, and organizations are frequently instructed to allowlist the provider's entire IP range. A "trial account" refers to a free or short-term account that anyone, including an attacker, can easily register on these shared platforms. This question explores whether sending a malicious email from an unrelated trial account on the same shared infrastructure allows the attacker to inherit the trust granted by the allowlist and bypass filtering.
3. **RQ3: What percentage of default phishing domains used by major SAT vendors are currently unregistered and vulnerable to takeover?**
   Vendors utilize a variety of domains to build their simulation infrastructure, including domains for sending emails and tracking user clicks. Organizations are often required to explicitly allowlist these specific domains. This question aims to measure the risk by analyzing the Domain Name System (DNS) registration status of these default domains to determine how many are currently unregistered.
4. **RQ4: What technical strategies can minimize the attack surface**

created by SAT allowlist configurations while preserving the effectiveness of the training program?
This question focuses on developing and testing alternative configurations that close these security gaps without stopping the security awareness training programs from functioning properly.

The goal of this thesis is to answer these research questions by identifying the conditions under which SAT allowlist vulnerabilities can be exploited. To achieve this, we accurately replicate real-world attack techniques without exposing actual enterprise networks to malicious activity. To do this, we simulate common allowlist setups and conduct controlled experiments within a dedicated Microsoft 365 sandbox environment. This sandbox acts as a safe, completely isolated testing space, allowing us to evaluate exploits without risking real organizational systems or user data.

To address our goals, the study is broken down into specific testing phases. First, we establish the default filtering behavior before any allowlist configurations are applied. To address RQ1, we evaluate whether an attacker can bypass spam filters using injected custom headers. To address RQ2, we test whether an unrelated attacker account on a shared delivery platform can exploit an IP-based allowlist. To address RQ3, we check for any abandoned vendor domains vulnerable to takeover. We also test the baseline filtering behavior in a live production environment. To address RQ4, the collected data is analyzed to identify and propose technical mitigations.

1.1 Scope

This thesis focuses on security risks introduced by allowlisting mechanisms that are used in phishing awareness training and simulated phishing attacks. The study is limited to email-based phishing attacks and the risks introduced by reconfiguring allowlists.

The simulated training attacks are restricted to a controlled laboratory environment that simulates a corporate email infrastructure using GoPhish [5], which is a free open-source phishing framework. The main goal is to investigate the technical exploitability rather than the effectiveness of training programs.

The analysis of SAT vendor infrastructures is limited to publicly available documentation and free trial accounts. This thesis does not analyze all SAT vendors or all possible allowlisting configurations, but instead focuses on the most commonly recommended setups used by organizations.

Finally, all simulated attacks are performed under strict ethical constraints. The accounts and emails used in the experiment are owned by the authors no real users or organizations are involved. This work followed responsible disclosure practices. No serious vulnerabilities were found that required notifying any vendors. If anything critical had been uncovered, it would have been reported directly to the affected parties so they could address the issue before any technical details were shared publicly. It is important to remember that the goal of this thesis is to improve defensive security practices and not enable new malicious activity.

1.2 Thesis outline

The remainder of this thesis is organized as follows. Chapter 2 provides the technical background necessary to understand email authentication protocols, Microsoft Defender filtering, and mechanics of allowlisting. Chapter 3 reviews related literature concerning phishing susceptibility, vulnerabilities in email authentication, and the risks of shared cloud infrastructure. Chapter 4 provides the threat model, experimental methodology, and the testing phases used to evaluate the configurations. Chapter 5 presents the results of the tests across different allowlist setups. Chapter 6 discusses the experimental findings, their implications, mitigation strategies, ethics, and limitations. Chapter 7 concludes the thesis by summarizing the key findings.

2

Background

This chapter establishes the technical foundation required to understand the vulnerabilities introduced by SAT allowlists. Section 2.1 introduces the relevant email identity and sender fields defined by Simple Mail Transfer Protocol (SMTP), as specified in RFC 5321 [6]. Section 2.2 explains the main email authentication protocols used to reduce spoofing risks, including Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), and Domain-based Message Authentication, Reporting, and Conformance (DMARC). Section 2.3 discusses layered email security and phishing defense mechanisms. Section 2.4 explains the operational mechanics of allowlisting, while Section 2.5 describes how allowlisting is used to support security awareness training and simulated phishing campaigns.

2.1 Email Identity and Sender Fields

To understand how email authentication protocols operate and how attackers can exploit allowlist configurations, it is necessary to distinguish between the various identity fields defined by SMTP. An email transaction consists of two parts: the SMTP envelope (used by mail servers for routing) and the message data (which includes the headers displayed to the users). Because these fields serve different purposes, they are evaluated independently by different security components, such as SPF verifiers, spam filters, and allowlist rules. These components evaluate the specific information contained within each field, such as domain names, IP addresses, or custom headers, to determine whether the email is legitimate or if it should be blocked. Attackers can manipulate specific fields, such as injecting custom SAT headers, to trigger an allowlist bypass while simultaneously forging the visible sender address to deceive the end user. The key fields relevant to understanding these exploits are:

- **`HELO/EHLO`:** The command used by a sending Mail Transfer Agent (MTA) to identify its host machine to the receiving server at the very beginning of SMTP connection.
- **`MAIL FROM` (Envelope sender):** The address used by the mail server to route non-delivery reports if a message cannot be delivered. This address is typically hidden from the recipient's view and is included into the final message as the `Return-Path`. It is the primary identity verified by SPF.
- **`From` Header:** The address displayed to the recipient in their email client, representing the author of the message. Because this is the only address the user actually sees, it is the primary target for spoofing. DMARC specifically

checks whether this header aligns with the domains authenticated by SPF or DKIM.

- **`Sender` Header**: A header used when the entity transmitting the message is different from the author listed in the `From` header. This is common when an automated system, mailing list, or delegated assistant sends a message on behalf of someone else.
- **`Resent-From` Header:** A header applied when an email is forwarded or redirected by a user or automated agent. It identifies the account that forwarded the message while intentionally preserving the original `From` header.

2.2 Email Authentication Protocols

Email was not originally designed with sender authentication in mind. The SMTP, defined in RFC 5321, allows any server on the internet to send a message claiming to originate from any domain without any built-in mechanism to verify that claim. To address this, three email authentication protocols have been standardized and are now widely deployed: **SPF**, **DKIM**, and **DMARC**. These protocols provide the basis for verifying whether a message was sent by an authorized source and whether the visible sender domain can be trusted.

SPF allows a domain owner to publish a Domain Name System (DNS) record specifying which IP addresses are authorized to send email on behalf of that domain. When a receiving mail server gets an incoming message, it queries the `MAIL FROM` domain's SPF record and checks whether the sending IP address is listed. If the IP is not authorized, the message fails SPF. The result is recorded in the message headers and passed to downstream filtering components. One limitation of SPF is that it authenticates the envelope sender, not the `From` header that is visible to the recipient, and it breaks when email is forwarded because the forwarding server's IP is not listed in the original domain's SPF record.

DKIM uses asymmetric cryptography to allow a sending mail server to attach a digital signature to outgoing messages. The signature is generated using a private key held by the sender and covers specific message headers and the body. The receiving server retrieves the corresponding public key from DNS and verifies the signature. If the message was altered in transit, the signature fails. DKIM provides integrity protection for the signed portions of the message and survives email forwarding, unlike SPF, because the signature travels with the message.

DMARC builds on top of SPF and DKIM by adding an alignment requirement and a policy mechanism. When a receiving server evaluates a message, DMARC checks whether the domain in the visible `From` header aligns with the domain authenticated by either SPF or DKIM. If neither passes alignment, the receiving server enforces the domain owner's published DMARC policy, which can be set to none, quarantine, or reject. DMARC also provides a reporting mechanism that allows domain owners to receive aggregated feedback about authentication failures for their domain.

Together, these three protocols form the primary technical defense against email spoofing. However, as the Related Work chapter 3 will discuss, each protocol has known weaknesses that can be exploited individually or in combination. Understanding how they interact is essential for interpreting the experimental results (See

Chapter 5) in this thesis, particularly when addressing RQ2, where authentication signals were deliberately manipulated to test whether allowlist rules override them.

2.3 Email Security and Phishing Defense

Email security relies on multiple layers of defense that operate in sequence before a message reaches the recipient's inbox. These layers include sender reputation checks, authentication protocol evaluation, dynamic URL analysis, attachment scanning, and content-based spam classification. Each layer is designed to catch a different class of threat, and a message must pass all of them to reach the inbox under normal conditions.

Microsoft Defender for Office 365 implements this layered approach through what Microsoft refers to as its protection stack. Incoming messages pass through connection filtering, which checks the sending IP against known blocklists, then through anti-malware scanning, anti-spam filtering, anti-phishing analysis, and finally Safe Links and Safe Attachments processing for advanced threat protection. The Spam Confidence Level (SCL) is a numeric score assigned to each message during this process, ranging from -1 to 9, where higher values indicate greater confidence that the message is spam. A score of -1 specifically indicates that spam filtering was bypassed entirely, typically because a transport rule or allowlist entry instructed the system to skip evaluation [7].

The Secure Email Gateway (SEG) sits between the public internet and the organization's mail infrastructure and is responsible for enforcing these filtering policies before messages are delivered to Exchange Online. This creates a direct conflict with SAT platforms, because simulated phishing emails are designed to closely resemble real-world attacks and will therefore be caught and blocked by the same filters they are trying to test. Without configuration changes, a simulated phishing email sent by a SAT vendor would be quarantined before reaching any employee's inbox, making the training exercise impossible to run.

2.4 Allowlisting

An allowlist in the context of email security is a configuration that instructs the filtering system to treat certain senders, IP addresses, domains, or message attributes as trusted and exempt from one or more filtering layers. Allowlists are a standard operational tool used by email administrators to ensure that legitimate business email from known senders is not incorrectly blocked by aggressive spam or phishing filters.

In Microsoft 365, allowlisting can be configured at several levels. Connection Filter Allow Lists operate at the network level and instruct the system to skip spam filtering for messages arriving from specific IP addresses or IP ranges. Exchange Transport Rules (ETRs), also called mail flow rules, can be configured to match specific message attributes such as headers, sender domains, or subject line patterns, and apply actions including setting the SCL to -1 to bypass spam filtering. The Tenant Allow/Block List allows administrators to explicitly permit specific senders

or domains, overriding SPF, DKIM, and DMARC failure outcomes for those entries. Each of these mechanisms bypasses filtering at a different point in the protection stack. A Connection Filter allowlist entry bypasses filtering before the message is evaluated for spam or phishing content. A transport rule that sets SCL to -1 bypasses spam classification but may still allow malware scanning to proceed.

2.5 Security Awareness Training Platforms

SAT is a method of user training that provides organizations with the capability to simulate phishing attacks and assess employee susceptibility to social engineering. Major platforms in this space include KnowBe4 [8], Cofense [9], Proofpoint [10], and Microsoft Attack Simulation Training [11]. These platforms operate by sending simulated phishing emails to employees from vendor-controlled infrastructure, tracking which employees click links or submit credentials, and delivering targeted training to those who fail the simulation.

For simulated phishing emails to reach employee inboxes, they must pass through the same email security stack that is designed to block real phishing attacks. SAT vendors address this by publishing allowlisting guides that instruct their clients to configure specific allowlist entries in their email security platform before running a simulation campaign. These guides typically recommend one or more of the following: adding the vendor's sending IP ranges to the Connection Filter Allow List, creating ETRs that bypass spam filtering for emails containing a vendor-specific custom header, and adding the vendor's sending domains to the Tenant Allow/Block List.

The problem with these configurations is that they prioritize reliable delivery of training emails over security hardening. Custom headers such as `X-PHISHTEST` can be easily added to any outgoing message by an attacker with direct SMTP access, making header-based transport rules exploitable by anyone who knows the header name. For example, an attacker could send a malicious email that looks like this:

```
From: attacker@gmail.com
To: user@company.com
X-PHISHTEST: true
Subject: Urgent action required
```

Because the organization's security gateway sees the trusted `X-PHISHTEST` header, it bypasses standard spam filtering and delivers the email directly to the user's inbox. IP-based allowlists extend trust to an entire shared IP pool rather than to a specific vendor account. This means any other tenant on the same shared infrastructure can send emails from IP addresses already approved by the target organization. For example, if an organization allowlists the IP range of a cloud email provider like SendGrid to permit training emails, an attacker can register a free SendGrid trial account. Any malicious email sent from the attacker's trial account will originate from the trusted IP range and bypass the organization's email filtering.

Domain-based allowlists can be exploited if default simulation domains used by vendors are not actively registered. An attacker could register an unregistered do-

main and send malicious emails from it with the full benefit of the allowlist entry. For example, if a vendor instructs organizations to allowlist a domain like `secure-internal-update.com`, but the vendor does not register that domain, an attacker can register it. The attacker now owns a domain that the target organization's security gateway is configured to trust.
Bypassing multiple layers of email security for SAT traffic creates an inconsistent security posture between simulated and real attacks. During an active training window, a real attacker who is aware of the allowlist configuration could exploit these relaxed settings to increase the likelihood that genuine phishing emails reach employee inboxes [12]. This is the core problem that this thesis investigates: the allowlist configurations that make SAT operationally possible are themselves a security vulnerability.

3
Related Work

This chapter reviews existing literature to contextualize the security risks introduced by SAT allowlisting. The review is structured around five areas. Section 3.1 examines the human factors of phishing deception and the operational drivers behind security awareness training. Section 3.2 explores the structural vulnerabilities introduced by static allowlisting mechanisms. Sections 3.3 and 3.4 analyze the fragility of email authentication protocols, focusing on identity field inconsistencies and the exploitation of shared cloud infrastructure. Finally, Section 3.5 establishes the necessity of pre-click filtering and discusses the defense layers that SAT allowlists bypass.

3.1 Phishing Attacks and Security Awareness Training

A foundational study for understanding why phishing remains effective despite years of defensive investment is Dhamija et al. [13], who conducted one of the first empirical investigations into the human factors behind phishing deception. Their study presented 22 participants with 20 websites, some legitimate and some fraudulent, and asked them to identify which were spoofed. The best-crafted phishing website in the study fooled 90% of participants, and on average participants made incorrect judgments 40% of the time across all sites. The authors categorized participants into five strategy types based on which security indicators they consulted, ranging from those who relied solely on page content and visual design to those who checked SSL certificates. The group that never looked beyond the visual appearance of a page made up 23% of participants and received the five lowest scores. The study also found no significant correlation between phishing susceptibility and age, education level, sex, or hours of computer use per week, meaning that experience and technical background offered no reliable protection against well-crafted attacks.
The paper identifies three categories of attack strategy that explain why phishing succeeds: lack of knowledge, visual deception, and bounded attention. The lack of knowledge category covers users who do not understand how domain names and SSL work, as well as users who are simply unaware that website spoofing is possible at all. The visual deception category covers techniques such as typejacking, images that mimic browser chrome, and rogue popup windows placed over legitimate pages. The bounded attention category covers the users who have the right knowledge and can spot visual deception will still fail if security indicators fall outside their focus of attention. The authors also list forged email headers as an explicit attack vector

under the lack of knowledge category, noting that most users do not have the skills to distinguish a forged header from a legitimate one. The Dhamija et al. [13] findings establish that users cannot be relied upon to catch what the technical filters miss, which is the core motivation behind deploying SAT platforms and the phishing simulations they deliver.

While Dhamija et al. [13] established in 2006 that users struggle to detect phishing on their own, a 2025 study by Ho et al. [14] questions whether SAT actually addresses this gap in practice. They ran an 8-month experiment across nearly 20,000 employees at UC San Diego Health. The study evaluated two common forms of SAT: annual cybersecurity awareness training, delivered through KnowBe4, and embedded anti-phishing training, where employees who fail a simulated phishing test are immediately redirected to educational material. The study used ten different phishing campaigns and included explicit control groups who received no training at all, which is something that much of the prior research lacked. Their key finding on annual training is that there is no statistically significant relationship between how recently an employee completed their annual awareness training and whether they failed a simulated phishing attack, with an odds ratio of 0.998 per 30-day increase. For embedded training, users in training groups were on average only 1.7% less likely to fail than users in the control group, and for several phishing campaigns over 10% of users in every group still failed. The paper also reports that between 37% and 51% of the users who were redirected to embedded training sessions immediately closed the page without interacting with the content, and only 24% of users formally completed the training material. The authors argue this high abandonment rate explains why real-world studies consistently show weaker results than lab-based evaluations where users engage voluntarily.

The authors note that during months 3 and 4 of their study, the allowlisting rules configured in Office 365 for the Phishing simulation platform were set up incorrectly, which caused nearly all simulated phishing emails to be quarantined before reaching the affected cohorts. Those cohorts had to be excluded from the analysis entirely. The authors describe the required configuration as follows: specific rules were added in Office 365 for the phishing simulation domains and email content to prevent Office 365 from quarantining these emails and from crawling the embedded URLs. A separate misconfiguration around URL crawling also required an additional data-cleaning step to remove failure events where the clicking IP address corresponded to Microsoft's own infrastructure rather than a real user. This is one of the few academic papers that surfaces the technical complexity of allowlisting configurations required to run SAT campaigns, even though it does not treat those configurations as a security risk in their own right. The incident shows that allowlisting for SAT involves deliberately disabling specific filtering layers in a production Microsoft 365 tenant, and that getting it wrong in either direction has measurable consequences.

To understand why organizations are willing to weaken their filtering infrastructure to support SAT, it is necessary to examine the psychological mechanics of successful phishing. Toth et al. [15] demonstrate that modern attacks rely heavily on subtle social cues, personalization, and internal sender appearance, which require highly realistic simulation emails to replicate. Their research also provides useful insights into how phishing emails succeed and the content they use, stating that successful

phishing messages often use combinations of cues such as personalization, internal sender appearance, and altruistic framing. Messages that appeared to originate from inside the organization, included personalized details, or appealed to helpfulness achieved higher compromise rates than generic messages. It also shows that traditional authority-based emails had weaker effects than expected, which suggests that phishing based on trust, familiar situations, and subtle social cues tends to trick people more effectively than pressure or threats. These findings are important because they help explain why large organizations are willing to reconfigure their allowlists and security controls to support phishing simulations. They also show that SAT-based training emails must often resemble genuine attacks closely enough to trigger authentic user responses. However, the more realistic such emails become, the more likely they are to be blocked by existing email defenses such as spam filtering, anti-phishing engines, authentication checks, or Uniform Resource Locator (URL) protection. This is one of the main reasons why organizations choose to reconfigure their allowlists for SAT platforms [15].
The relevance of this section to the thesis is that it explains exactly why organizations create these vulnerable allowlist configurations in the first place. Because users struggle to identify phishing on their own, organizations rely on SAT platforms to train them. However, to make this training effective, the simulated emails must look exactly like real attacks. Because they look like real attacks, normal email filters will block them. To prevent the training emails from being blocked, organizations are required to configure allowlists that bypass their own security filters. This thesis specifically investigates the security vulnerabilities created when organizations disable these filters.

3.2 Security implications of Allowlisting

In addition to the context of user training, allowlisting itself introduces inherent structural vulnerabilities to an organization's security posture. Castle Rock Sky [12] outlines how static trust assignments degrade over time, noting that prioritizing deliverability via allowlists inherently weakens defenses against malware and phishing. These static trust assignments degrade over time because allowlists often remain unchanged even when business relationships change or when the allowlisted sources become outdated. This creates persistent trust in potentially risky sources as the total number of allowlisted sources grows over time. Another risk is that if an allowlisted sender is spoofed or compromised, malicious and phishing emails can be delivered to users' inboxes without any filtering, increasing the risk of malware infection and theft of credential information. Lastly, the article suggests focusing on authentication mechanisms such as SPF, DKIM, and DMARC rather than relying only on allowlists when developing email security mechanisms.
The security risks introduced by allowlisting are not unique to email infrastructure, but represent a broader architectural flaw in access control mechanisms. Zhang and Lin [19] demonstrate a parallel vulnerability in Bluetooth Low Energy Networks where allowlisting trusted devices creates a reliable tracking side channel. The main reason to use allowlisting in this context is to restrict connections to a specific trusted peer, but this creates different behavior toward allowlisted versus non-allowlisted

peers. In Bluetooth's advertising phase, the device exhibits very simple behavior; it either responds to a device or ignores it. An example of this is a peripheral device such as headphones that can be set to respond to scan requests from a specific approved device, such as the user's own phone, while ignoring every other device. On the other hand, a central device such as the user's own phone can be set to automatically connect to devices with which it has been paired before, such as headphones. The problem is that even though the devices change their address or use a temporary address for privacy, their simple and predictable behavior can reveal them in such a way that an attacker can observe these response patterns, determine which temporary address belongs to the device, and use it to track the device over time.
The relevance of this section to the thesis is that it shows allowlisting itself is a security risk, even outside of user training. The thesis argues that SAT allowlists are dangerous because they weaken an organization's email security. This section supports that argument by explaining that allowlists often remain unchanged over time, which creates persistent trust in potentially risky sources. If an allowlisted sender is spoofed, malicious emails bypass the filters and reach the inbox. Furthermore, the Bluetooth example shows that attackers can exploit the predictable behavior of allowlists in other technologies. This is exactly what the thesis investigates in the context of email. Just as an attacker can reuse a trusted Bluetooth address to exploit an allowlist, this thesis demonstrates how an attacker can reuse a trusted SAT header or a shared IP address to exploit an email allowlist.

3.3 Vulnerabilities in Email Authentication Protocols

The technical feasibility of exploiting SAT allowlist configurations relies heavily on fundamental weaknesses in the broader email authentication chain. Chen et al. [16] highlight this weakness by identifying 18 distinct evasion exploits across major email providers, all of which exploit inconsistencies in how different systems process email identity fields. The core insight of the paper is that SMTP defines multiple sender identity fields that serve different purposes in the delivery chain: the `MAIL FROM` envelope address, the `From` header displayed to the user, the `HELO` command, the `Sender` header, and the `Resent-From` header. Each component in the processing chain, including the SPF verifier, the DKIM verifier, the DMARC alignment checker, and the MTA, independently parses and prioritizes these fields. Because different components are built by different developers following specifications that leave room for interpretation, the same message can be authenticated as legitimate by one component while being displayed as a spoofed sender by another. If at least one security component blocked the message, there would be no problem. However, the problem is that attackers exploit this confusion so that the message is not blocked at all. The attacker crafts the email so that the security component responsible for authenticating the message evaluates a legitimate field, while the email client displaying the message to the user evaluates a completely different, forged field. Because the security component approves the message, the email is never blocked.

It bypasses the filters and reaches the inbox, where the user only sees the spoofed sender address.

The paper organizes the attacks into three classes: **intra-server attacks**, **UI-mismatch attacks**, and **ambiguous-replay attacks**. Intra-server attacks exploit inconsistencies between components within a single email server. For example, in the HELO/MAIL FROM confusion attack, when the SPF component cannot verify the `MAIL FROM` address because it belongs to a non-existent subdomain, some implementations fall back to verifying the `HELO` identifier instead. The DMARC component, however, still uses the `MAIL FROM` domain for its alignment test because the address is technically non-empty. The two components end up authenticating different identifiers, and the spoofed message passes. UI-mismatch attacks exploit inconsistencies between what the server authenticates and what the mail client displays to the user. An attacker can craft a message with two `From` headers where the server uses the first one for DMARC verification but the email client displays the second one. Ambiguous-replay attacks abuse the fact that DKIM does not prevent message replay: an attacker who obtains a legitimately signed email from a real domain can append malicious content to the body without breaking the signature, then forward it to victims who see an email that passes DKIM and DMARC validation.

The paper also tested four major third-party sending services, namely Amazon SES, SendGrid, Mailgun, and SparkPost, and found that none of them adequately validated the `From` header in outgoing messages. SendGrid and Mailgun allowed arbitrary `From` headers, while SES and SparkPost could be bypassed using the ambiguous address techniques described in the paper. The authors note that all four services validated the `MAIL FROM` and DKIM domains strictly by verifying domain ownership, which made full DMARC bypass difficult in that specific scenario, but they flag this as an ongoing concern given that DMARC deployment and enforcement in the wild are inconsistent. An attacker with an account on the same platform can exploit the trust that the target organization has already extended to that platform's IP range and sending infrastructure.

Shen et al. [17] extend this line of work with a larger-scale analysis covering 30 popular email services and 23 email clients, finding that all of them are vulnerable to at least some of the 14 spoofing attack techniques they identified. The authors argue that email security depends entirely on the weakest link in a chain involving senders, receivers, forwarders, and UI renderers, and that a failure at any single stage breaks the entire chain-based defense. The ETR that grants bypass based on the presence of a custom header is effectively one weak link that an attacker can target while the rest of the chain remains intact.

The paper organizes attacks across four authentication stages. In the sending authentication stage, attackers can exploit inconsistencies between the `Auth username`, `MAIL FROM`, and `From` headers. Shen et al. [17] show that many email services fail to enforce consistency between these fields, allowing an attacker to send an email whose authenticated username differs from the displayed sender. The shared MTA attack model, where an attacker who holds a legitimate account on the same mail transfer agent as the impersonated sender. Under this model, the attacker's sending IP is already within the target domain's SPF scope, and the platform may automatically

attach a DKIM signature, so the spoofed message passes all three authentication protocols without any additional manipulation.
The finding from the forwarding verification stage is also worth noting. The paper demonstrates that some email forwarding services add a DKIM signature to all forwarded messages without first verifying whether the original message passed DKIM validation. Office 365 and Alibaba Cloud were both found vulnerable to this attack in their experiments. This means an attacker can register a forwarding account, send a spoofed message to it, and receive a legitimately signed copy in return that passes DKIM and DMARC at the destination. The paper also reports that only 12 of the 30 tested services implement any form of sender inconsistency checks, which are UI-level alerts that notify the recipient when the `MAIL FROM` and `From` headers do not match. The absence of this check in the majority of services means that even when the authentication protocols are working as intended, the displayed sender address can still mislead the recipient. Together, the Chen et al. [16] and Shen et al. [17] papers establish that the email authentication chain has structural weaknesses at multiple stages, and that these weaknesses are not theoretical but demonstrably exploitable across the most widely used email services in the world.
The relevance of this section to the thesis is that it explains how attackers can combine existing email vulnerabilities with SAT allowlists. The thesis investigates how attackers exploit allowlists by manipulating specific email fields, such as custom headers. This section supports that by showing that the email authentication chain already has structural weaknesses because different security components check different fields. Because different components check different fields, an attacker can craft an email where the security component evaluates a legitimate field, while the user sees a completely different, forged field. When an organization configures an allowlist for SAT, they create an intentional weak link in this chain. They configure the security gateway to trust a specific header or IP address and ignore the normal authentication checks. An attacker can use the techniques described in this section to forge the visible sender address, and then use the SAT header or IP address to bypass the security gateway. This allows the malicious email to reach the inbox without being blocked.

3.4 Shared Cloud Infrastructure

The most directly relevant prior work to this thesis is BreakSPF by Wang et al. [18], presented at NDSS 2024, which investigates how the widespread use of shared cloud infrastructures creates structural vulnerabilities in SPF specifically. While the studies discussed in Section 3.3 focus on inconsistencies between components in the authentication chain, BreakSPF focuses on a different problem: the trust model of SPF itself breaks down when organizations outsource their email delivery to shared cloud platforms like SendGrid or Amazon SES. When a company adds one of these providers to their SPF record, they are not authorizing their own specific account on that platform. They are authorizing every tenant that shares the same IP pool. An attacker who creates a free or trial account on the same platform can send emails that originate from those same authorized IP addresses. The receiving server checks the IP, finds a match in the SPF record, and passes the message through.

To measure how widespread this problem is, the researchers collected 87,430 IP addresses from five categories of shared infrastructure, including cloud servers, proxy services, serverless functions, CI/CD platforms, and content delivery networks. By mapping these addresses against SPF records from the Tranco top one million domains, they found that 23,916 domains were vulnerable to spoofing attacks through this method. Among the most commonly included providers in vulnerable SPF records were shared email services like SendGrid and Amazon SES. Many SAT platforms rely on this same type of shared cloud infrastructure to deliver their simulated emails. To ensure these simulated emails reach the inbox, organizations often allowlist the IP ranges associated with the underlying cloud provider. Because the infrastructure is shared, allowlisting these IP ranges means any other tenant on that same cloud platform can also bypass the organization's email filters.
The BreakSPF paper establishes shared cloud infrastructure as a practical and scalable attack vector against SPF. However, their work focuses on the broader internet and general SPF misconfigurations. It does not examine the specific scenario where a security team has deliberately weakened its own filters to accommodate a third-party vendor, which introduces a different threat model entirely. This thesis applies the shared infrastructure concept to the SAT context. Because enterprise security teams are actively instructed by vendors to allowlist specific IP ranges, the conditions described by Wang et al. [18] are not just passively present but are intentionally configured. Notably, our own experimental setup uses SendGrid as the delivery infrastructure, placing it directly within the category of shared platforms that BreakSPF identified as exploitable. The methodology (See Chapter 4) details how we tested whether these vendor-prescribed configurations allow malicious payloads to bypass Microsoft Defender in the same way that BreakSPF demonstrated for general SPF records.

3.5 Necessity of Layered Email Defenses

Because modern spear-phishing campaigns frequently omit traditional indicators like malicious links, the pre-click filtering layers that SAT allowlists bypass are often an organization's most critical defensive barrier. Wood et al. [20] argue that rigorous, automated analysis of SMTP headers and authentication signals before user interaction is now essential. Most older security systems focus on detecting malicious websites after a user clicks on a link. For example, a browser may check whether a URL is listed as dangerous or display a warning page. The problem is that many modern phishing attacks do not depend on fake websites at all. Instead, they try to trick the recipient directly through the email message itself. This is especially common in **spear-phishing**, **whaling**, and Business Email Compromise (BEC) attacks. In this context, whaling refers to phishing attacks that target high-profile individuals such as executives or senior decision-makers. These attacks often aim to convince the recipient to transfer money, share sensitive information, or open a harmful attachment.
Because of this, the article argues that email filtering before the user interacts with the message is one of the most important areas of cybersecurity today. However, if the pre-click filtering is too harsh, it may block legitimate emails. This risk of

blocking legitimate emails is exactly why allowlists are so common. Organizations use allowlists to ensure that specific emails, such as simulated training emails, bypass the harsh filters so they are not accidentally blocked.

One of the most useful parts of Wood et al. [20] is its description of how phishing emails can be filtered by analyzing the email header. The header contains technical information about where the message came from and how it was sent. Important fields include the sender address, Reply-To address, Message-ID, Received path, and the sending IP address. Authentication methods such as SPF, DKIM, and DMARC are also important because they help verify whether the sender is legitimate. If an email claims to come from a company manager but fails authentication checks, or if the visible sender address does not match the Reply-To domain, this can be a strong sign of phishing. These types of checks are useful because they can be performed automatically before the email reaches the inbox. However, the relevance to this thesis is that SAT allowlists are configured to bypass these exact checks. When an organization configures an allowlist, they are telling the email platform to ignore the results of these checks so the simulated training emails are not blocked.

The paper also explains the importance of analyzing the content of the email body. Many phishing emails use urgent or emotional language to pressure the recipient into acting quickly. Common examples include phrases such as "urgent payment required," "your account will be closed," or "click here immediately." A filtering system can detect these patterns and combine them with other suspicious signs, such as hidden links, fake attachments, too many links, unusual formatting, or embedded forms asking for personal information. The paper also mentions language-based features such as grammar, readability, sentence structure, and vocabulary. This is important because phishing emails often rely on manipulation and social engineering rather than technical tricks alone.

Another major topic in Wood et al. [20] is the use of machine learning for email filtering. Instead of relying only on manually written rules, machine learning models can learn from large collections of phishing and legitimate emails. They can recognize patterns in writing style, sender behavior, header data, and link usage that may be difficult to detect with simple rules. This makes machine learning especially useful for catching new phishing attacks that are not yet listed in blocklists. However, the article also notes that these systems need good training data and regular updates, and they must be designed carefully to avoid blocking legitimate emails.

Wood et al. [20] also discusses authorship analysis, which can be valuable in organizations. The idea is that people often have consistent writing habits. If an email claims to be from a CEO or finance manager but the writing style is very different from their normal emails, the message may be fraudulent. This can help detect targeted impersonation attacks that look convincing at first glance.

This section is relevant to this thesis because it demonstrates that the allowlist configurations do not just bypass simple spam rules. Instead, they disable the advanced, layered defenses that organizations rely on to stop modern attacks.

3.6 Summary

As discussed in Sections 3.2, 3.3 and 3.5, no single filtering method is sufficient on its own. The best email filtering systems combine several layers of protection, including sender authentication, rule-based checks, content analysis, and machine learning. When organizations configure SAT allowlists, they deliberately bypass this layered defense, creating a single point of failure that attackers can exploit.

4
Methods

This chapter describes the experimental methodology used to evaluate whether allowlist configurations for phishing awareness training can be abused to bypass enterprise email filtering. The methodology is organized around five components. First, Section 4.1 defines the threat model and identifies the attacker capabilities considered in this study. Second, Section 4.2 describes the controlled experimental environments, including the Microsoft 365 target tenant and the sender infrastructure used to deliver test messages. Third, Section 4.3 defines the payload categories and explains how message content was standardized across experiments. Fourth, Section 4.4 presents the experimental phases used to test header-based allowlisting, shared infrastructure abuse, and domain lifecycle risks. Finally, Section 4.5 explains how delivery outcomes, authentication results, and Microsoft Defender filtering signals were collected and analyzed.

The study follows a controlled experimental security-testing approach. A dedicated sender environment was used to generate email messages that imitate realistic allowlist-abuse scenarios, while a separate Microsoft 365 E3 sandbox tenant was used as the target environment. This setup allowed the experiments to reproduce common enterprise allowlisting configurations without involving real users, production mailboxes, or external organizations. The goal was not to conduct phishing against users, but to measure how specific allowlist rules changed the technical handling of email messages by Microsoft 365 and Microsoft Defender.

All experiments were conducted exclusively on infrastructure owned and operated by the authors. Test messages were sent only to mailboxes controlled by the authors, and no real employees, third-party organizations, or unauthorized systems were involved. Potentially harmful content was represented using safe test artifacts, such as the EICAR test file, rather than real malware. This ensured that the experiments remained controlled, repeatable, and ethically bounded while still allowing the security effect of the allowlist configurations to be measured.

4.1 Threat Model

To analyze the security implications of allowlisting in a structured way, this thesis uses a threat model focused on realistic abuse scenarios. The purpose of the model is to identify how trust granted to support phishing simulations may be misused by external adversaries or weakened through internal configuration choices.

To reflect different levels of attacker access and different types of defender misconfiguration, four threat categories are considered. For each one, we outline the baseline

capabilities the attacker needs, the specific abuse method those capabilities enable, the potential security impact, and the practical limitations that shape how realistic the scenario is.

- **External Attacker Abusing Allowlist Configurations:** Requires basic internet routing capabilities, the technical ability to forge SMTP headers (e.g., injecting X-PHISHTEST), and skills to identify target's SAT vendor.
- **External Attacker with SAT Platform Access:** Requires the ability to successfully register, verify, and operate a trial or paid account on the same shared email delivery infrastructure (eg., SendGrid) used by the target's SAT vendor.
- **External Attacker Exploiting Domain Lifecycle Weaknesses:** Requires automated tooling to monitor domain expirations (WHOIS Registration Data Protocol (WHOIS) tracking), financial resources to register dropped domains, and the ability to configure DNS records for the hijacked infrastructure.
- **Internal Misconfiguration/Defender Model Weaknesses:** Requires legitimate administrative access to mail-flow settings and email-security policies. In this case, the risk comes from allowlist rules that are too broad or too permissive, not from a malicious insider. Examples include transport rules that force the Spam Confidence Level to –1 based only on a custom header, large shared IP allowlists, or domain entries that override SPF, DKIM, and DMARC failures. These kinds of configurations don't compromise the organization on their own, but they widen the attack surface and make it easier for external actors to take advantage of weakened filtering logic.

These scenarios vary in access and capability, but each shows how allowlisting can increase the email attack surface. Table 4.1 summarizes their impact and limitations. The threat categories are not fully separate in practice. External attackers often rely on internal configuration weaknesses to make their techniques work. For instance, spoofing a header like X-PHISHTEST only matters if an administrator has already created a transport rule that trusts that header without checking who sent the message. Likewise, abusing shared delivery infrastructure only becomes feasible when an organization allowlists a broad IP range instead of restricting access to a specific, authenticated sender. The table therefore highlights both the attacker's capabilities and the defender-side conditions that enable each type of abuse.

Table 4.1: Threat model summarizing abuse methods, potential impact, and practical limitations across four allowlist-related threat categories.

Threat Category	Capabilities & Abuse Method	Potential Damage	Limitations / What They Cannot Do
External Attacker Abusing Allowlist Configurations	**Capabilities:** Can forge SMTP headers and route external email. **Method:** Spoofs trusted indicators such as custom SAT headers (e.g., `X-PHISHTEST`), exploits weak Exchange Transport Rules, or sends from infrastructure covered by permissive allowlists.	Higher probability of inbox delivery, improved phishing success, credential theft, and reduced effectiveness of reputation-based filtering.	No direct access to administrative systems, cannot guarantee delivery if additional controls still apply, and cannot compromise accounts without user interaction.
External Attacker with SAT Platform Access	**Capabilities:** Holds a verified account on shared vendor infrastructure. **Method:** Uses a free, trial, or compromised SAT/vendor account to send emails through shared infrastructure already trusted by the target organization.	High-deliverability phishing campaigns, increased message credibility, and easier bypass of basic filtering logic.	Cannot change the victim's security policies and is limited by the provider's sending thresholds. The account can also be suspended if the service detects abuse, policy violations, or unusual sending patterns.

Table 4.1 – continued from previous page

Threat Category	Capabilities & Abuse Method	Potential Damage	Limitations
External Attacker Exploiting Domain Lifecycle Weaknesses	**Capabilities:** Can track/register expired domains and manage DNS. **Method:** Registers expired, abandoned, or previously trusted SAT-related domains that remain present in outdated allowlists or user trust assumptions.	Trusted-looking phishing emails, persistent stealth abuse, credential harvesting, and exploitation of historical trust relationships.	Requires domain availability, fails if stale trust entries were removed, and may still be blocked by content scanning or strict authentication policies.
Internal Misconfiguration / Defender Model Weaknesses	**Capabilities:** Valid administrative access to email routing policies. **Method:** Administrators create overly broad exceptions such as SCL = -1 bypasses, large shared IP allowlists, or domain rules that override SPF/DKIM/DMARC failures.	Expanded attack surface, policy drift over time, weaker filtering effectiveness, and easier exploitation by external attackers.	Does not directly compromise systems by itself; real impact requires attacker traffic, user interaction, or continued poor governance.

4.2 Experimental Environments

The experiments were split into a target environment and a sender environment. Keeping them separate made it easier to distinguish between the system being evaluated and the system generating the test messages. The target environment acted as the receiving organization, while the sender environment represented the external infrastructure used to deliver the controlled test emails.

The target environment was a dedicated Microsoft 365 E3 sandbox tenant, configured to simulate a corporate email infrastructure. The tenant was provisioned with Exchange Online and Microsoft Defender for Office 365, with default security baselines applied before any allowlist modifications were introduced. A dedicated mailbox within this tenant served as the recipient for all test emails across every phase of the experiment. Three allowlist configurations were applied and tested in sequence, each corresponding to a distinct phase of the experiment: a header-based ETR, an IP-based, and a domain-based allowlist entry.

The sender environment handled campaign management and delivery via GoPhish, an open-source phishing framework hosted on a local Linux machine. To simulate different attack vectors, the delivery infrastructure was split across two tools. In this context, the attack vectors refer to the different technical paths an external sender could use to exploit allowlist trust: spoofing a trusted simulation header, sending through a shared cloud email provider that has been allowlisted, or abusing a previously trusted domain. For header-based bypass experiments, GoPhish was used as the primary campaign delivery tool. However, during baseline testing, messages sent through GoPhish were consistently delivered to the Junk folder, even when the payload content was benign. This suggests that Microsoft Defender considered factors beyond the message body itself, such as sender reputation, SMTP behavior, sending domain reputation, or infrastructure-related signals associated with the GoPhish delivery setup. To isolate this variable, `swaks` (Swiss Army Knife for SMTP) was used as an alternative delivery tool in the baseline phase to confirm that Microsoft Defender's classification was driven by GoPhish's sender reputation rather than payload content. This was not independently verified and is therefore treated as an interpretation of the observed delivery behavior rather than a confirmed cause. For shared infrastructure experiments, a free-tier SendGrid account was used as the delivery relay, with the test domain `venkatac.dev` registered and authenticated through SendGrid's domain verification process. A second test domain, `anasmasri.xyz`, was authenticated on a separate SendGrid account to represent an unrelated tenant sharing the same IP pool.[1] A shared IP pool means that multiple independent customers send emails through the same provider-managed sending IP addresses. As a result, an allowlist rule based only on those IP addresses may trust all senders using that pool, not only the intended SAT vendor or test account.

[1]The domains `venkatac.dev` and `anasmasri.xyz` were owned and controlled by the thesis authors during the experiments.

4.3 Payload Specification

To ensure results were comparable across different allowlist configurations, all payload content was standardized. Content variables were minimized to focus specifically on how allowlist logic processed the email, rather than how the spam filter analyzed its content.

4.3.1 Payload Categories

Four payload categories were used to test different aspects of the security stack:

- **P0: Benign Control.** Plain informational text used to confirm basic delivery without triggering threat scanners.
- **P1: Spam-like Text.** Contains keywords commonly flagged by spam filters, such as urgent account suspension warnings and requests to verify account activity, to observe whether allowlisting overrides standard spam classification.
- **P2: Simulated Phish.** Contains a single URL pointing to a controlled tracking page to test whether URL rewriting and click-through protection were bypassed when allowlist rules were active.
- **P3: Malware (EICAR).** Contains the industry-standard EICAR test file as an attachment to test whether malware scanning policies were overridden by allowlist configurations in the same way that spam and phishing filters were.

4.3.2 Content Format

Content format was varied in a controlled way to test whether the allowlist behavior was consistent across common email formats. The text-based payloads (P0–P2) were sent as both plain-text and HTML messages because real email campaigns may use either format, and security filters may process them differently. Message length was also varied to check whether short and long versions of the same payload category produced different filtering outcomes. Apart from format and length, the message structure was kept consistent so that differences in delivery outcome could be attributed to the allowlist configuration rather than unrelated changes in content.

P3 was handled differently because it tested attachment scanning rather than message-body filtering. For this category, the email body was kept simple, while the EICAR test file was attached using the selected attachment method. This made it possible to observe whether malware scanning remained active even when spam or phishing filtering was bypassed.

- **Format:** Both `text/plain` and `text/html` versions were sent to ensure allowlisting applied to both MIME types.
- **Length:** A short variant of 20–50 words and a long variant of 150–200 words were used to determine whether message body size influenced transport rule processing.

4.3.3 Indicator Injection

For the header-spoofing experiments, the simulation indicator `X-PHISHTEST: true` was injected as a top-level header in the raw message data using `GoPhish`. All payloads included a unique identifier in the subject line to support reliable correlation across sender logs, mailbox delivery records, and Microsoft 365 admin traces.

4.4 Experimental Phases

Testing was structured across five phases, each building on the previous one to progressively introduce and evaluate different allowlist configurations. Methodology is mapped to Research Questions as follows:

- **Phase 1 (Baseline Establishment):** Establishes default filtering behavior before any RQs are tested.
- **Phase 2 (Header Spoofing):** Directly addresses **RQ1** by evaluating whether an attacker can bypass spam filters using injected custom headers.
- **Phase 3 (Shared Infrastructure Abuse):** Directly addresses **RQ2** by testing whether an unrelated attacker account on a shared delivery platform can exploit an IP-based allowlist.
- **Phase 4 (Domain Analysis):** Directly addresses **RQ3** by quantifying the percentage of abandoned vendor domains vulnerable to takeover.
- **Phase 5 (Production Validation):** Validates the empirical findings of RQ1 and RQ2 in a live production environment.

  The data collected across all these phases is analyzed in Chapter 6 to formulate technical mitigations, which directly addresses **RQ4**.

4.4.1 Phase 1: Baseline Establishment

Before any allowlist configurations were applied to the target tenant, all payloads were delivered to establish how Microsoft Defender classified external email by default. Two baseline sub-experiments were conducted. First, payloads were sent using `swaks` directly to the target tenant's MX record to observe how a clean SMTP sender with no prior reputation was handled. Second, the same payloads were sent through GoPhish to see whether the delivery tool or sending setup influenced how Microsoft Defender classified the messages. This step helped determine whether the filtering differences were tied to non-content factors such as sender reputation, SMTP behavior, domain reputation, or characteristics of the GoPhish infrastructure. The GoPhish emails were consistently delivered to Junk even for benign payloads, while the `swaks` emails reached the Inbox, confirming that the difference in outcome was attributable to GoPhish's sender reputation rather than email content. This distinction was important for interpreting the results of subsequent phases, where GoPhish was used as the primary delivery tool.

4.4.2 Phase 2: Header Spoofing

An ETR was configured in the target tenant to set the SCL to −1 for any incoming message containing the header `X-PHISHTEST: true`. This mirrors the allowlisting guidance published by major SAT vendors, which recommends using custom header-based transport rules to ensure simulated phishing emails bypass spam filtering. Once the rule was active, all payloads were resent using `swaks` with the `X-PHISHTEST: true` header injected into the raw message.

To test whether the transport rule's bypass persisted independently of email authentication, the experiment was run under three authentication conditions: first with valid SPF, DKIM, and DMARC alignment, then with SPF deliberately failed by removing the SendGrid include from the domain's SPF record, and finally with DKIM failed by removing the public key from DNS so that signature verification could not complete.

4.4.3 Phase 3: Shared Infrastructure Abuse

The target tenant's ETR Allow List was updated to include the IP ranges used by SendGrid's shared sending pool. Two sub-experiments were run under this configuration.

In the first, payloads were sent from the primary attacker account on SendGrid using the authenticated domain `venkatac.dev`, representing the expected legitimate SAT vendor traffic originating from an authorized sender. In the second, the same payloads were sent from a completely separate SendGrid account using a different domain, `anasmasri.xyz`, which had no relationship to the target tenant and had not been explicitly authorized by it. Both accounts sent from the same shared IP pool, meaning the IP-based allowlist applied equally to both. This second sub-experiment directly tested the shared infrastructure abuse scenario described in RQ2, where an attacker with a trial account on the same platform can exploit an allowlist that was configured for a different tenant's legitimate vendor if the domain was used by some vendor in the past.

4.4.4 Phase 4: Domain Analysis

Default sending and landing domains used by major SAT vendors were collected from their publicly available allowlisting documentation. A scripted WHOIS lookup process was run against this domain list to determine the current registration status of each domain. For each domain, the registration status was recorded as registered or unregistered, along with the registrar and relevant timestamp metadata where available. The measurement date was recorded for each lookup, given that WHOIS data can change over time. Domains found to be unregistered were flagged as potentially available for takeover, which would allow an attacker to register the domain and receive traffic intended for legitimate SAT simulation infrastructure.

4.4.5 Phase 5: Production Validation

A limited production validation is planned for a live university Microsoft 365 tenant using only the authors' own university mailboxes. This phase requires written authorization from the university information security team before any testing can begin. The scope will be narrowly limited to a small number of safe payloads over a short time window. No other university users, mailboxes, or distribution lists will be involved. This phase is intended to verify whether the vulnerabilities confirmed in the sandbox environment persist in a production tenant with real-world security configurations applied.

4.5 Data Collection and Analysis

For each test email, the final delivery outcome was recorded as one of four states: Inbox, Junk, Quarantine, or Rejected. Emails delivered to the mailbox were exported as raw `.eml` files and inspected for Microsoft anti-spam headers. Quarantined messages were captured through the Exchange admin quarantine portal and message trace logs. For every email, the following data points were extracted and logged:

1. **Delivery outcome and location:** The final handling of the message, recorded as *Inbox*, *Junk*, *Quarantine*, or *Rejected*. Inbox and Junk placement were determined from mailbox folder placement, while Quarantine and Rejected outcomes were determined from message trace and quarantine records.
2. **Authentication results (SPF/DKIM/DMARC):** The status of SPF, DKIM, and DMARC as reported in the received message headers, recorded as Pass, Fail, or None. Where available, alignment-related cues were also noted, specifically whether the authenticated domain corresponded to the visible `From:` address.
3. **Filtering and classification signals:** Microsoft 365 stamps detailed filtering metadata into anti-spam headers. The following signals were parsed and recorded:
    - **SCL (Spam Confidence Level):** The numeric score assigned to the message. Cases where the SCL was set to -1 were flagged specifically, as this value indicates that spam filtering was bypassed by a transport rule rather than passed through normal evaluation.
    - **CAT (Category):** The threat category label assigned by Microsoft Defender, used to capture whether the system treated the email as spam, phish, or benign.

For the domain analysis in Phase 4, WHOIS lookups were performed for all identified vendor-related sending and landing domains. For each domain, the registration status, registrar, and relevant timestamp metadata, including creation, update, and expiry dates, were recorded where available. The measurement date was logged for each lookup to account for the possibility that registration status changes over time.

5
Results

This chapter presents the outcomes of the experimental phases defined in Section 4.4, using the data collection process described in Section 4.5.

5.1 Phase 1: Baseline Establishment

Two baseline sub-experiments were conducted before any allowlist configurations were applied to the target tenant. In the first, all payloads were delivered using `swaks` directly to the target tenant's Mail Exchange Record (MX) record. Benign, spam, and phishing payloads all reached the Inbox, while both malware payloads, the long and short were quarantined. In the second, the same payloads were delivered through GoPhish. All non-malware payloads were delivered to Junk regardless of content type, and both malware payloads were quarantined. The results are presented in Table 5.1 and 5.2.

Category	Quarantine	Junk/Spam	Inbox
Benign Long			✓
Benign Short			✓
Spam Long			✓
Spam Short			✓
Phish Long			✓
Phish Short			✓
Malware Long	✓		
Malware Short	✓		

Table 5.1: Phase 1 baseline results using Swaks

The difference in outcome between the two tools was consistent across all payload types. Benign, spam, and phishing payloads sent through GoPhish were all delivered to Junk, while the same payloads sent through `swaks` reached the Inbox. This confirmed that the classification difference was driven by GoPhish's sender reputation rather than by the content of the emails. Malware payloads were quarantined regardless of which tool was used, indicating that Microsoft Defender's malware scanning operates independently of sender reputation signals.

Category	Quarantine	Junk/Spam	Inbox
Benign Long		✓	
Benign Short		✓	
Spam Long		✓	
Spam Short		✓	
Phish Long		✓	
Phish Short		✓	
Malware Long	✓		
Malware Short	✓		

Table 5.2: Phase 1 baseline results using GoPhish

5.2 Phase 2: Header Spoofing

An ETR was configured to set the SCL to −1 for any incoming message containing the header `X-PHISHTEST: true`. All payloads were then resent from GoPhish with this header injected. The results are presented in Table 5.3.

Category	Quarantine	Junk/Spam	Inbox
Benign Long			✓
Benign Short			✓
Spam Long			✓
Spam Short			✓
Phish Long			✓
Phish Short			✓
Malware Long	✓		
Malware Short	✓		

Table 5.3: Phase 2 results after applying the `X-PHISHTEST` header-based transport rule

The presence of the `X-PHISHTEST: true` header was sufficient to move all non-malware payloads from Junk to Inbox, regardless of their content. Benign, spam, and phishing payloads all bypassed spam filtering and were delivered directly to the Inbox. This held true across all authentication conditions tested, including deliberately failed SPF, DKIM, and DMARC, confirming that the transport rule override was applied before any authentication-based filtering took place. The EICAR attachment variants stayed in Quarantine under every tested condition. This shows

that Microsoft Defender's malware scanning worked independently of the spam bypass created by the transport rule. In practice, setting the SCL to –1 bypassed spam and phishing checks, but it did not turn off or weaken attachment-based malware detection.

5.3 Phase 3: Shared Infrastructure Abuse

The target tenant's ETR Allow List was updated to include SendGrid's shared IP ranges. Two sub-experiments were conducted under this configuration. In the first, payloads were sent from a SendGrid account representing the intended SAT sender, using the authenticated test domain `venkatac.dev`. In the second, the same payloads were sent from a separate attacker-controlled SendGrid account using a different authenticated test domain, `anasmasri.xyz`, which had no relationship to the target tenant. Both accounts used SendGrid's shared sending infrastructure, allowing the experiment to test whether an IP-based allowlist distinguished between the intended SAT sender and an unrelated sender on the same provider infrastructure. The results for both sub-experiments are presented in Table 5.4 and Table 5.5, respectively.

Category	Quarantine	Junk/Spam	Inbox
Benign Long			✓
Benign Short			✓
Spam Long			✓
Spam Short			✓
Phish Long			✓
Phish Short			✓
Malware Long	✓		
Malware Short	✓		

Table 5.4: Phase 3 results using the authorized SendGrid account (`venkatac.dev`)

Both sub-experiments produced identical outcomes. All non-malware payloads reached the Inbox regardless of which SendGrid account or domain they originated from, and malware payloads were quarantined in both cases. The IP-based allowlist made no distinction between the authorized vendor account and the unrelated attacker account, since both sent from the same shared IP pool. This confirms that allowlisting a shared infrastructure provider's IP range effectively grants inbox access to any tenant on that platform, not just the intended vendor.

Category	Quarantine	Junk/Spam	Inbox
Benign Long			✓
Benign Short			✓
Spam Long			✓
Spam Short			✓
Phish Long			✓
Phish Short			✓
Malware Long	✓		
Malware Short	✓		

Table 5.5: Phase 3 results using an unrelated SendGrid account (`anasmasri.xyz`)

5.4 Phase 4: Domain Analysis

The analysis shows that SAT vendors rely on a wide mix of domains for sending emails, hosting landing pages, tracking clicks, and running backend services. This setup makes phishing simulations more realistic, but it also creates a complex and sometimes messy infrastructure where older or rarely monitored domains can quietly become weak points. Even though no immediate takeover risks were found, the presence of legacy domains and constantly shifting infrastructure means that vulnerabilities can appear over time, especially when outdated domains remain in allowlists or documentation.
Another key difference lies in how vendors manage their infrastructure. External SAT providers depend on dedicated or shared domains that organizations must explicitly allowlist, while integrated platforms like Microsoft's Attack Simulation Training mostly use already trusted internal domains. This distinction directly affects the size of the attack surface and the types of risks introduced through allowlisting. Overall, the findings show that domain-based allowlisting is necessary but also creates implicit trust relationships that require careful oversight, supporting the threat scenarios and mitigation strategies discussed in the thesis.

5.4.1 knowBe4

The following table summarizes the domains identified for the KnowBe4 platform.

Table 5.6: KnowBe4 Domain Analysis

Domain	Type	Registered	Registrar	Notes
knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	Main corporate domain
training.knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	Official training portal
learner.knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	User training interface
phishing.knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	Used in phishing simulations
info.knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	Marketing / notification emails
mail.knowbe4.com	Sending	Yes	Amazon Registrar, Inc.	Mail infrastructure reference
support.knowbe4.com	Service	Yes	Amazon Registrar, Inc.	Help center / documentation
kb4.io	Landing	Yes	Gandi SAS	Link tracking domain
telefon-de.com	Landing	Yes	Amazon Registrar, Inc.	Used in KnowBe4 simulations
secured-login.net	Landing	Yes	Amazon Registrar, Inc.	Appears in ANY.RUN output for a KnowBe4 training flow
ispservices.co.uk	Landing	Yes	Gandi	Officially referenced for sending/spoof allow-list context
ispservices.net	Landing	Yes	Amazon Registrar, Inc.	Officially referenced for sending/spoof allow-list context
online-login-portal.com	Landing	Yes	Amazon Registrar, Inc.	Officially referenced for sending/spoof allow-list context

5.4.2 Cofense

The following table summarizes the domains identified for the Cofense platform.

Domain	Type	Registered	Registrar	Notes
cofense.com	Sending	Yes	MarkMonitor	Main corporate domain
training.cofense.com	Sending	Yes	MarkMonitor	Training platform domain
support.cofense.com	Service	Yes	MarkMonitor	Help center / documentation
phishme.com	Sending	Yes	MarkMonitor	Legacy Cofense (PhishMe) domain
landing.phishme.com	Landing	Yes	MarkMonitor	Simulation pages/assets
landing.phishme.com	Landing	Yes	MarkMonitor	Simulation pages/assets
complaints.defendid.us	Landing	Yes	MarkMonitor	“Phishing Simulation” and shows references involving
digitalfileportal.com	Landing	Yes	MarkMonitor	““Phishing Simulation” and shows landing.phishme.com in response headers.

Table 5.7: Cofense Domain Analysis

5.4.3 Microsoft (Attack Simulation Training)

The following table summarizes the domains identified for Microsoft Attack Simulation Training.

Domain	Type	Registered	Registrar	Notes
microsoft.com	Sending	Yes	MarkMonitor	Main Microsoft domain
office.com	Service	Yes	MarkMonitor	Microsoft service domain
outlook.com	Sending	Yes	MarkMonitor	Email delivery infrastructure
microsoftonline.com	Service	Yes	MarkMonitor	Authentication and tenant services
security.microsoft.com	Service	Yes	MarkMonitor	Defender portal and simulation control
protection.outlook.com	Sending	Yes	MarkMonitor	Exchange Online Protection infrastructure
attack simulation-training.com	Sending	Yes	Nom-iq Ltd. dba COM LAUDE	End-user training notifications / assignment reminders after simulations
attemplate.com	Landing	Yes	Nom-iq Ltd. dba COM LAUDE	domains/URLs Microsoft lists as used by Attack Simulation Training
bankmenia.com	Landing	Yes	MarkMonitor	domains/URLs Microsoft lists as used by Attack Simulation Training
doctrings.org	Landing	Yes	MarkMonitor	domains/URLs Microsoft lists as used by Attack Simulation Training

Table 5.8: Microsoft Attack Simulation Training Domain Analysis

5.4.4 Proofpoint

The following table summarizes the domains identified for Proofpoint phishing simulation.

Domain	Type	Registered	Registrar	Notes
securityeducation.com	Sending / Landing	Yes	MarkMonitor Inc.	Main domain listed for Proofpoint SAT safelisting and Advanced Delivery
ws01-securityeducation.com	Landing	Yes	Markmonitor Inc.	Additional Proofpoint SAT web filtering domain
platform.securityeducation.com	Landing	Yes	Markmonitor Inc.	US training platform and simulation assets
platform-web-eu.securityeducation.com	Landing	Yes	Markmonitor Inc.	EU training platform and simulation assets
phishingtraining.eu	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing simulation domain
avoidphishing.eu.securityeducation.com	Landing	Yes	Markmonitor Inc.	Teachable Moment / phishing education domain
youarebeingphished.com	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint simulation landing domain
security-education.net	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing simulation domain
emaildistro.net	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing campaign domain
emailquarantine.net	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing campaign domain
exch01-corp.net	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing campaign domain
corpoutlook.co.uk	Landing	Yes	Markmonitor Inc.	Publicly listed Proofpoint phishing campaign domain

Table 5.9: Proofpoint Security Awareness Training Domain Analysis

5.4.5 Hoxhunt

The following table summarizes the domains identified for Hoxhunt phishing simulation.

Domain	Type	Registered	Registrar	Notes
hoxhuntsigning.com	Sending	Yes	Cloudflare, Inc.	DKIM signing domain used for Hoxhunt training emails
game.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt end-user training dashboard
app.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt platform and training interface
auth.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt login and authentication domain
response.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt feedback and response pages
api.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt backend and GraphQL API endpoint
admin.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt Admin Portal
insights.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt insights and reporting interface
reports.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt reports portal
officejs.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt Outlook web add-in service
public.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt Outlook add-in public resources
cdn.hoxhunt.com	Landing	Yes	Cloudflare, Inc.	Hoxhunt static content and CDN resources

Table 5.10: Hoxhunt Domain Analysis

5.4.6 Infosec IQ

The following table summarizes the domains identified for Infosec IQ phishing simulations.

Table 5.11: Infosec IQ Domain Analysis

Domain	Type	Registered	Registrar	Notes
securityiqmail.net	Sending	Yes	Amazon Registrar, Inc.	DKIM domain used for Infosec IQ phishing simulations

Continued on next page

Domain	Type	Registered	Registrar	Notes
securityiq-notifications.com	Sending	Yes	Amazon Registrar, Inc.	DKIM / notification domain used for Infosec IQ allowlisting
securityiq.info-secinstitute.com	Landing	Yes	Amazon Registrar, Inc.	Infosec IQ platform and phishing simulation portal
securityiq-eu.infosecinstitute.com	Landing	Yes	Amazon Registrar, Inc.	EU Infosec IQ platform domain referenced in allowlisting guidance
infosecinstitute.com	Landing	Yes	Amazon Registrar, Inc.	Main Infosec corporate and product domain

5.4.7 Barracuda

The following table summarizes the domains identified for Barracuda phishing simulation.

Table 5.12: Barracuda Security Awareness Training Domain Analysis

Domain	Type	Registered	Registrar	Notes
spearphish.com	Sending	Yes	Go France Domains, LLC	Used in Barracuda SAT Return-Path behavior for email-only domains
mail.spearphish.com	Sending	Yes	Go France Domains, LLC	Barracuda-documented SMTP/MX host for replies and delivery notifications
phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda Security Awareness Training admin, LMS, and content domain
lms.phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda Security Awareness Training LMS domain
lmscs.phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda-documented LMS/content allowlist domain
lmsjs.phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda-documented LMS/content allowlist domain

Continued on next page

Domain	Type	Registered	Registrar	Notes
lmsps.phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda-documented LMS/content allowlist domain
lp.phishline.com	Landing	Yes	GoDaddy.com, LLC	Barracuda sample landing page domain referenced in release notes
barracuda.com	Landing	Yes	CSC Corporate Domains, Inc.	Main Barracuda corporate and product domain
barracudanetworks.com	Landing	Yes	CSC Corporate Domains, Inc.	Barracuda Cloud Control login and product access domain
login.barracudanetworks.com	Landing	Yes	CSC Corporate Domains, Inc.	Login domain used to access Barracuda Security Awareness Training
campus.barracuda.com	Landing	Yes	CSC Corporate Domains, Inc.	Barracuda Campus documentation and support content domain

5.5 RS4: Real-World Environment

This section presents the results from RS4, which evaluates the behavior of the tested payloads in a real-world sandbox using Chalmers email infrastructure. Unlike the earlier controlled Microsoft 365 sandbox experiments, this scenario was designed to observe how the messages were handled in a more realistic institutional mail environment. The purpose of this test was to compare whether the delivery patterns observed in the controlled phases would also appear when the same categories of messages were sent through a real email security stack.

The RS4 experiment was divided into two delivery methods: GoPhish and `swaks`. Both methods were used to send the same payload categories, including benign, spam, phishing, and malware test messages, with both short and long variants. For each message, the final delivery outcome was recorded as Inbox, Junk/Spam, or Quarantine. These results help evaluate whether the Chalmers mail environment allowed, downgraded, or blocked the tested messages, and they provide an additional point of comparison against the earlier allowlisting experiments.

5.5.1 Using GoPhish

Category	Quarantine	Junk/Spam	Inbox
Benign Long		✓	
Benign Short		✓	
Spam Long	✓		
Spam Short		✓	
Phish Long	✓		
Phish Short		✓	
Malware Long	✓		
Malware Short	✓		

Table 5.13: RS4 results using GoPhish in the Chalmers mail environment

5.5.2 Using Swaks

Category	Quarantine	Junk/Spam	Inbox
Benign Long		✓	
Benign Short		✓	
Spam Long	✓		
Spam Short		✓	
Phish Long	✓		
Phish Short		✓	
Malware Long	✓		
Malware Short	✓		

Table 5.14: RS4 results using `Swaks` in the Chalmers mail environment

6
Discussion

This chapter reflects on the results presented in Chapter 5 and connects them back to the research questions introduced in Chapter 1. Section 6.1 looks at the baseline findings and explains how they serve as a reference point for the later allowlist experiments. Section 6.2 discusses the header-based allowlisting results in relation to RQ1. Section 6.3 examines the shared-infrastructure results and how they relate to RQ2. Section 6.4 reviews the vendor-domain analysis and its implications for RQ3. Section 6.5 presents the real-world sandbox validation. Section 6.6 compares the outcomes across all experimental phases. Section 6.7 considers what the findings mean for security awareness training. Section 6.8 outlines technical mitigation strategies. Section 6.9 discusses the ethical aspects of the study, and Section 6.10 summarizes the study's limitations and finally Section 6.11 points to possible directions for future work.

The central takeaway is that **Common allowlisting practices used for phishing simulations can unintentionally widen the security boundary of an enterprise mail system.** In the Microsoft 365 sandbox, both header-based and IP-based allowlisting caused non-malware messages to be delivered to the Inbox, even when they contained content that resembled spam or phishing. Once an allowlist rule matched, it outweighed the content-based signals that would normally influence delivery. At the same time, malware payloads were still quarantined, showing that not all layers were bypassed. The outcome is therefore not a full breakdown of Microsoft Defender, but a meaningful weakening of the protection stack: spam and phishing detection were bypassed, while malware scanning continued to function.

This distinction matters because many phishing attacks succeed without using traditional malware. A credential-harvesting link, a fake invoice, or a business email compromise message does not need a malicious attachment to be effective. If an allowlist prevents these messages from being evaluated by normal spam and phishing filters, the burden shifts to the user to recognize the threat after it reaches their inbox. This runs counter to the layered-defense approach described earlier, where technical controls are meant to reduce user exposure in the first place. The experiments show that poorly scoped SAT allowlists can unintentionally turn a training requirement into a potential delivery path for real attacks.

6.1 Interpretation of the Baseline Results

The baseline phase established how the sandbox behaved before any allowlist rules were introduced. This step matters because it provides the reference point needed to

understand the impact of the later configurations. The two baseline sub-experiments produced different outcomes for non-malware messages depending on the sending tool. Messages sent through GoPhish were delivered to Junk, while messages sent with `swaks` directly to the tenant's MX record reached the Inbox. Malware payloads were quarantined in both cases.
The difference between GoPhish and `swaks` shows that Microsoft Defender did not rely solely on message content when deciding how to classify the email. If content had been the dominant factor, the same benign, spam, and phishing payloads would have produced similar results regardless of the sending method. Instead, GoPhish traffic consistently landed in Junk—even when the payload was benign. This points to the influence of non-content signals such as sender reputation, delivery infrastructure, message structure, or other metadata. This aligns with how modern filtering systems operate: phishing detection is not treated as a simple text-classification task but as a combination of signals including infrastructure, authentication, historical reputation, formatting, and behavioral indicators.
This baseline strengthens the later findings. Because GoPhish messages were initially treated as suspicious, the shift of those same message categories into the Inbox after applying the `X-PHISHTEST` transport rule cannot be explained by pre-existing trust. The baseline demonstrated that Microsoft Defender did not inherently trust GoPhish traffic. Therefore, the Inbox delivery observed in Phase 2 reflects a clear change caused by the allowlist rule. In other words, the header-based bypass did not simply maintain a favorable classification—it overrode an unfavorable one.
The baseline also confirms that the sandbox's security controls were functioning as expected. Malware payloads were quarantined before any allowlisting and continued to be quarantined afterward. This prevents misinterpreting the results as evidence of a generally insecure or misconfigured tenant. The system did block the most obviously malicious category. The weakness emerged only when administrative allowlist rules instructed the system to skip or reduce parts of its spam and phishing evaluation. The issue is therefore not a lack of defensive capability, but the way trusted exceptions reshape the normal decision process.
Another notable observation is that benign, spam, and phishing payloads behaved identically within each baseline delivery path. Through GoPhish, all non-malware messages went to Junk. Through `swaks`, all non-malware messages reached the Inbox. This shows that, in the tested configuration, content differences alone were not enough to produce different outcomes. This does not mean content analysis is unimportant in general rather, it highlights that the combined filtering decision in this sandbox was heavily influenced by delivery context and reputation. For SAT allowlisting, this is significant because simulation providers often use predictable infrastructure, and organizations may tune their filters to trust that infrastructure. If infrastructure trust becomes the dominant factor, attackers who can imitate or share that infrastructure may gain a meaningful advantage.

6.2 Header-Based Allowlisting and RQ1

Phase 2 examined RQ1 directly: whether an attacker could bypass enterprise spam filtering by spoofing common simulation headers such as `X-PHISHTEST`. In the sand-

box environment, the answer was unambiguous. Once an ETR was configured to set the SCL to 1 for any message containing `X-PHISHTEST: true`, every non-malware payload was delivered to the Inbox. This applied to benign, spam, and phishing payloads alike. The behavior remained the same even when authentication signals were intentionally broken, including failing SPF, DKIM, and DMARC checks.

These results highlight the core weakness of relying on unauthenticated headers for allowlisting. A custom header is not a reliable security identifier on its own. Because headers are part of the message body, any sender with control over the raw message or the sending tool can insert them. Unless the receiving system verifies that the header was added by an authenticated and authorized source, it functions only as a label. When a mail flow rule treats that label as proof of legitimacy, an attacker simply needs to reproduce the label to benefit from the rule.

The experiment therefore confirms that header-based SAT allowlisting can create a straightforward trust-confusion issue. The organization intends the header to mean "this message came from our approved simulation provider." The mail server, however, only sees "this message contains a matching string." These are fundamentally different claims. The first is an authenticated assertion about origin; the second is just a message attribute. Without additional constraints—such as a known sending domain, a specific certificate, a trusted tenant, or a verified DKIM signature—the rule cannot distinguish legitimate simulation traffic from attacker-generated traffic.

The fact that messages with failed authentication still reached the Inbox is especially significant. SPF, DKIM, and DMARC are designed to make sender identity harder to forge. Yet the Phase 2 results show that a transport rule can effectively override the practical impact of those failures for spam and phishing classification. This does not imply that authentication checks were skipped; rather, the allowlist rule carried more weight in the final delivery decision than the negative authentication signals. This creates a problematic ordering: a rule added for operational convenience can weaken the protections offered by protocols specifically designed to prevent impersonation.

This finding aligns with related work showing that email authentication mechanisms can interact in unexpected ways when systems combine signals incorrectly. The experiment extends that concern into the SAT allowlisting context. The issue is not only that authentication protocols have known limitations; it is that organizations may introduce local exceptions that reduce the value of those protocols. A domain may publish a strict DMARC policy, yet a receiver may still deliver a suspicious message if a local rule sets the SCL to 1 based on a spoofable header.

The broader security implication is that header-based allowlisting should not be treated as a standalone trust mechanism. It may be reasonable as one condition within a more restrictive rule, but not as the sole criterion. A safer interpretation of a custom SAT header is that it serves as an internal routing marker—useful only after the message's origin has already been verified. It should not, on its own, establish trust.

6.3 Shared Infrastructure Abuse and RQ2

Phase 3 explored RQ2 by testing whether an unrelated sender using the same shared email delivery provider could benefit from an IP-based allowlist. The target tenant's allowlist included SendGrid's shared IP ranges. Payloads were sent from two different SendGrid accounts: one representing the expected authorized sender using `venkatac.dev`, and another using the unrelated domain `anasmasri.xyz`. Both accounts produced the same outcome. All non-malware payloads were delivered to the Inbox, while malware payloads were quarantined.

This shows that an IP-based allowlist on shared infrastructure grants trust at the infrastructure level rather than at the level of a specific vendor account. From the receiving tenant's perspective, the rule matched the sending IP range and nothing more. It did not distinguish between the intended SAT vendor account, another tenant on the same platform, or an attacker-controlled account using the same shared pool. As a result, the trust boundary became broader than what the organization likely intended.

This risk is common in cloud-based email delivery. Shared infrastructure is appealing because it is scalable and easy to operate. Vendors can send large volumes of simulation emails without requiring dedicated infrastructure for each customer. But the same model creates ambiguity when the receiver allowlists the infrastructure instead of a more specific identity. If multiple unrelated tenants can send from the same IP pool, then allowlisting that pool effectively extends trust to all of them—not just the one the organization meant to trust.

The Phase 3 results are important because they demonstrate a realistic abuse path that does not require compromising the legitimate SAT vendor. An attacker does not need access to the vendor's actual account if they can obtain access to the same shared delivery environment through a separate account. In the experiment, the unrelated account had no connection to the target tenant, yet it still benefited from the IP-based allowlist. This directly supports the concern behind RQ2: **broad IP allowlisting can unintentionally transfer trust from a legitimate provider to unrelated tenants**

The findings also illustrate why IP addresses are a weak identity signal in multi-tenant services. In traditional mail systems, an IP address often maps to a single organization or server. In modern cloud platforms, the same IP range may represent many customers with very different risk profiles. Treating a shared IP range as equivalent to a trusted sender collapses these distinct identities into a single security decision. This is especially problematic for SAT platforms because their emails intentionally resemble phishing. Organizations have a strong operational incentive to bypass filters for these messages. But if that bypass is applied at the shared-provider level, it may also apply to traffic that was never part of the training program.

A more secure approach would narrow the trust relationship to something that identifies the authorized sender more precisely. Examples include a dedicated sending IP, a vendor-specific subdomain with aligned DKIM, a customer-specific return path, or authenticated message signatures that cannot be generated by other tenants. The key principle is that the allowlist condition should match the entity the organization actually intends to trust. If the trusted entity is the SAT vendor—or a specific

customer simulation account—then the rule should not rely solely on an IP range shared with unrelated senders.

6.4 Domain Analysis and RQ3

Phase 4 addressed RQ3 by examining the domains used by major SAT vendors. The analysis did not identify any unregistered domains within the main sets reviewed. On the surface, this is reassuring: the core domains used for sending, landing pages, training portals, and support infrastructure appear to be properly registered and professionally maintained. This lowers the immediate likelihood of a straightforward domain-takeover attack against the primary domains included in the study.

However, the absence of unregistered domains in the main sets should not be taken as evidence that domain-based allowlisting is inherently safe. The analysis highlights a broader structural issue: SAT ecosystems rely on a wide range of domains with different roles, histories, and ownership patterns. Some domains handle sending, others host landing pages, tracking endpoints, login flows, content, or training dashboards. Some are core corporate domains, while others are campaign-specific, legacy, regional, or tied to third-party services. This diversity increases operational complexity and makes it difficult for organizations to maintain accurate allowlists over time.

The real risk is not limited to whether a primary vendor domain is registered at a single point in time. Domain ownership and usage can shift. Documentation can lag behind reality. Training templates may reference older domains. Customers may copy allowlist entries from outdated deployment guides and leave them in place indefinitely. A domain that is safe today may become irrelevant later, and an irrelevant domain may still remain trusted inside an enterprise configuration. This creates a delayed-risk scenario: the vulnerability may only emerge after a domain expires, changes ownership, or falls out of active vendor use while still being present in customer allowlists.

This matters because domain-based allowlisting often outlives the training campaigns that prompted it. Administrators may add entries to support a simulation and then leave them in place—either to avoid breaking future campaigns or simply because the configuration is not revisited. Over time, the allowlist can accumulate many old trust decisions. Even if each decision was reasonable when made, the combined result may be a large set of trusted domains whose current relevance is unclear. The domain analysis reinforces this concern by showing that SAT infrastructure is not a single stable endpoint but a collection of many domains and services.

The analysis also shows that integrated and external platforms create different trust patterns. Microsoft Attack Simulation Training benefits from being part of the already trusted Microsoft 365 ecosystem. External SAT vendors, on the other hand, often require organizations to explicitly allowlist vendor-controlled domains, shared sending infrastructure, or training-specific landing domains. This does not make external vendors inherently insecure, but it does change the attack surface. External platforms require additional cross-organization trust relationships, while integrated platforms reuse trust relationships that already exist within the tenant. Both models introduce risk, but the nature of that risk differs.

For RQ3 specifically, the percentage of unregistered domains in the reviewed main vendor domain sets was zero. The key interpretation is that the most direct form of domain takeover was not observed in this dataset. Still, the broader domain-governance risk remains. Domain takeover is influenced by time, documentation, and operational practices—not just by whether a domain is registered at a single moment. A robust defense should therefore include periodic reviews, expiry monitoring, and the removal of stale allowlist entries rather than relying on a one-time assessment.

6.5 The Real-World Sandbox Results

The final experiment evaluated the payloads in a more realistic sandbox using two delivery methods: GoPhish and `swaks`. Both tools produced identical results, suggesting that in this setup the filtering decision was not strongly influenced by the sending tool itself. Instead, the system appears to have relied more on message content, sender reputation, authentication context, or broader campaign characteristics.

No payload category reached the Inbox. Benign long and short messages were placed in Junk/Spam, as were the short spam and short phishing messages. The long spam and long phishing messages were quarantined, along with both malware payloads. This shows that the real-world sandbox applied a stricter security posture than the earlier allowlisted phases, where several non-malware payloads reached the Inbox once a bypass rule was triggered. In this final configuration, the system either downgraded suspicious messages to Junk/Spam or blocked them entirely through quarantine.

The fact that even benign messages were sent to Junk/Spam is notable because it illustrates why organizations often rely on allowlists for SAT campaigns. Harmless simulation traffic may fail to reach users when it originates from unfamiliar or low-reputation infrastructure. Operationally, this makes allowlisting appealing because it improves delivery reliability. But the earlier phases showed that broad allowlisting can also create a bypass path for unauthorized messages. The real-world sandbox therefore highlights the central trade-off examined in this thesis: without allowlisting, phishing simulations may be blocked or filtered; with overly permissive allowlisting, real attackers may be able to exploit the same trust path.

The difference between the short and long spam/phishing payloads is also interesting. Short spam and phishing messages were sent to Junk/Spam, while the long versions were quarantined. This suggests that longer messages contained more indicators of suspicious behavior, giving the filtering system greater confidence that the message was harmful. For phishing simulations, this means that more detailed or realistic templates may be more likely to trigger stronger filtering actions. This reinforces a practical challenge for SAT providers: the more realistic the training email becomes, the more likely it is to resemble an actual threat and be blocked.

Malware detection remained effective throughout the experiment. Both malware payloads were quarantined for both GoPhish and `swaks`, consistent with earlier phases. This indicates that malware scanning continued to function as a strong protection layer even when other classifications varied. However, this should not be mistaken for comprehensive protection against phishing, since many real-world

phishing attacks succeed without using malware at all. Credential theft, fake login pages, invoice fraud, and business email compromise can all be carried out using only links or social-engineering content.

6.6 Cross-Phase Interpretation

The cross-phase results reveal two clear patterns. First, once an allowlist condition was triggered, the content category had little effect on how non-malware messages were handled. Benign, spam, and phishing payloads were treated the same within each allowlisted configuration. Second, malware payloads were quarantined in every phase. Taken together, these patterns show how the protection stack behaved under the tested conditions: allowlisting influenced spam and phishing placement, but it did not interfere with malware quarantine.

This separation has both encouraging and concerning implications. On the positive side, malware scanning remained robust across all bypass configurations. Even when a message matched a trusted header or originated from an allowlisted IP range, the EICAR payloads were still quarantined. This suggests that Microsoft Defender maintained a distinct malware-detection layer that was not disabled by the specific SCL bypass used in the experiments. From a defense-in-depth perspective, this is valuable because it prevents an allowlist from becoming a complete blind spot.

The downside is that many real phishing attacks do not rely on malware at all. Messages prompting users to visit fake login pages, approve fraudulent invoices, reset passwords, or authorize financial transfers can succeed without ever triggering attachment-based malware detection. If such messages reach the Inbox because spam and phishing filters are bypassed, the remaining defenses shift to user judgment, browser protections, link rewriting, or post-delivery remediation. These controls help, but they are not equivalent to preventing delivery in the first place.

The results therefore suggest that allowlisting shifts the balance between pre-delivery and post-delivery defenses. Under normal filtering, suspicious messages may be blocked, quarantined, or sent to Junk before users ever see them. Under broad SAT allowlisting, suspicious non-malware messages may be delivered directly to the Inbox, increasing the burden on users and downstream controls. In the context of SAT, this creates an ironic situation: the mechanisms used to test user awareness can increase reliance on user awareness if misconfigured.

The experiments also show that the risk is not tied to a specific payload format. Short and long variants behaved similarly in the completed phases, and both plain-text and HTML-like phishing content were represented. This indicates that the bypass was not sensitive to message length or formatting in the tested configuration. The decisive factor was whether the allowlist rule matched. This reinforces the conclusion that the vulnerability is structural rather than content-specific. The issue is not that one particular phishing email slipped through; the issue is that the allowlist rule created a category of messages for which normal spam and phishing evaluation was bypassed.

6.7 Implications for Security Awareness Training

The findings do not suggest that SAT is harmful or should be avoided. Security awareness training is still an essential part of organizational defense, especially because phishing often targets human decision-making. What the results do show is that the technical setup around SAT needs to be treated as a security-sensitive change rather than a routine configuration step. Allowlisting is not a neutral adjustment—it alters how the mail system evaluates incoming messages and can unintentionally create exploitable trust paths if it is too broad or not tied to strong authentication.

A central lesson is that simulation reliability and security assurance can pull in different directions. SAT vendors need their simulated phishing emails to reach users so that campaigns generate meaningful training data. Email security teams, on the other hand, want suspicious messages filtered before users ever see them. Allowlisting resolves this tension by prioritizing delivery, but the experiments show that this can weaken filtering for messages that merely appear to be part of the simulation. The goal is not to eliminate allowlisting entirely, but to make it precise, temporary, and verifiable.

Another implication is that organizations should treat SAT traffic as privileged test traffic. It should reach users only because it has been authenticated as part of an approved training activity and not because it contains a public header or comes from a broad shared IP range. This mirrors how other privileged integrations are handled: **trust should be based on strong identity, least privilege, and clear lifecycle management**. A SAT allowlist should have an owner, a justification, a review date, and defined conditions for removal.

The results also highlight the influence of vendor documentation on customer security. If allowlisting guides recommend broad IP ranges, simple headers, or long-lived bypass rules, many organizations will implement those instructions without fully understanding the security trade-offs. Vendors therefore share responsibility for making secure configurations the default. Good documentation should explain not only how to ensure successful delivery, but also how to avoid granting unnecessary trust to unrelated senders.

6.8 Mitigation Strategies

The mitigation strategies that follow from these results are grounded in the principle of least privilege: allow only the minimum traffic required for a training campaign, for the shortest necessary period, and rely on the strongest available identity signals. The goal is not to block SAT emails, but to prevent allowlists from becoming reusable by attackers.

First, organizations should avoid header-only bypass rules. A custom header such as `X-PHISHTEST` should never be the sole condition for setting the SCL to -1. If a header is used, it should be paired with stronger identity checks such as a verified sender domain, aligned DKIM, a known return-path domain, a dedicated sending IP, and a campaign-specific recipient scope. The rule should combine multiple con-

ditions rather than rely on a single, easily spoofed indicator. For example, a safer rule would require both a vendor-specific authenticated domain and the expected simulation header, rather than accepting the header from any sender.

Second, organizations should prefer dedicated infrastructure over shared infrastructure for simulation delivery. If a vendor can provide a dedicated sending IP or a customer-specific sending domain, that option is safer than allowlisting a broad shared IP pool. Dedicated infrastructure narrows the set of senders who can benefit from the rule. If shared infrastructure must be used, the allowlist should be constrained by additional identity checks so that unrelated tenants on the same provider cannot inherit trust.

Third, allowlists should be temporary and scoped to the campaign. Many of the risks described in this thesis become more serious when allowlists remain active indefinitely. A simulation window should have a defined start and end date, and mail flow rules should be disabled or removed once the campaign concludes. Where possible, organizations should automate this lifecycle so that bypass rules expire automatically. A rule that exists only during a short, approved campaign provides far less opportunity for abuse than a permanent exception.

Fourth, organizations should restrict allowlisted traffic to specific recipients or groups whenever possible. Phishing simulations are usually targeted at a defined population. If only a subset of users participates, the bypass should not apply tenant-wide. Scoping the rule to the intended recipients reduces the impact of abuse. If an attacker triggers the allowlist condition but sends to users outside the campaign group, the message should be processed by normal filtering.

Fifth, domain allowlists should be reviewed regularly. Although the Phase 4 analysis did not identify unregistered domains in the primary sets, domain risk changes over time. Organizations should maintain an inventory of all SAT-related domains and record why each entry is trusted. Domains that are no longer used by the vendor or no longer required for current campaigns should be removed. Expiry monitoring and ownership verification should be repeated periodically, especially for campaign-specific, legacy, or documentation-derived domains.

Sixth, organizations should monitor for unexpected use of SAT allowlist rules. A bypass rule should not operate silently. Security teams should log when the rule matches, which sender triggered it, which recipients received the message, and what authentication results were present. Alerts should be generated when the rule is matched outside an approved campaign window, by an unexpected sender, from an unexpected domain, or at unusual volume. This turns the allowlist from a silent bypass into a monitored exception.

Seventh, malware scanning, Safe Links, and Safe Attachments should remain enabled wherever possible. The experiments showed that malware scanning continued to quarantine the EICAR payloads even when spam bypass rules were active. This separation should be preserved. Organizations should avoid configurations that bypass more layers than necessary. If the goal is simply to prevent simulated phishing emails from going to Junk, there is usually no reason to disable malware scanning or link detonation for all matching messages.

Finally, vendors should strengthen the security posture of their recommended configurations. Vendor documentation should discourage header-only rules and broad

shared-IP allowlisting unless no safer alternative exists. Vendors should support customer-specific identifiers that cannot be generated by unrelated tenants. They should also provide clear lists of active domains, publish change notices when domains are retired, and avoid using unregistered or placeholder domains in templates, screenshots, or training content. Secure-by-default vendor guidance would reduce the likelihood that customers create unsafe exceptions.

6.9 Ethics

The experiments in this thesis involve phishing-like messages, simulated malicious content, spoofed indicators, and allowlist bypass testing. These techniques are inherently dual-use: they can help defenders understand weaknesses, but they could also be misused if applied against real organizations without authorization. Ethical handling is therefore central to the study.

The controlled sandbox design minimized risk by ensuring that no real users, third-party organizations, or external victims were targeted. All mailboxes and domains used in the experiments were controlled by the authors. The purpose was to examine configuration behavior, not to deceive employees or collect credentials. Payloads were created to test delivery outcomes rather than to cause harm. Malware testing relied on the EICAR test file, a standard benign test string used for validating anti-malware systems rather than functional malware.

The research also avoided interacting with live customers or attempting domain takeover. The domain analysis was limited to public documentation and registration-status checks. Even when discussing domain-governance risks, the study did not attempt to intercept traffic, impersonate vendors, or interact with real training campaigns. This limitation is ethically necessary, as domain takeover or traffic interception could expose private data and cause real organizational harm.

Another ethical consideration concerns disclosure and framing. The goal of the thesis is to support defensive improvement, not to provide operational attack guidance. The discussion therefore focuses on configuration weaknesses and mitigations rather than offering procedural instructions for exploitation. The findings are intended for administrators, vendors, and researchers who aim to reduce the attack surface created by SAT allowlists.

There is also an ethical responsibility to avoid overstating the results. The experiments show that certain allowlist configurations in a sandbox environment can bypass spam and phishing placement for non-malware payloads. They do not imply that every organization using SAT is vulnerable in the same way, nor do they show that malware scanning can be bypassed by these rules. Responsible interpretation requires presenting both the weaknesses observed and the controls that remained effective.

6.10 Limitations

This thesis does not measure employee susceptibility to phishing attacks or the long-term behavioral impact of security awareness training. The focus is technical:

how allowlist configurations influence email filtering outcomes. Human factors, user reporting behavior, and training effectiveness are therefore outside the scope of the completed experiments.

The study also does not cover every SAT vendor or every possible allowlisting configuration. The selected vendors and configurations represent common patterns, but enterprise deployments vary widely. Some organizations may use additional secure mail gateways, custom transport rules, conditional access policies, dedicated vendor infrastructure, or post-delivery detection tools that were not replicated in the sandbox. As a result, the findings should be interpreted as evidence of plausible and demonstrated configuration risks, not as a universal measurement of all production environments.

The Microsoft 365 sandbox may not fully reflect a mature enterprise tenant. Real organizations often have additional policies, historical reputation data, user-reporting workflows, threat intelligence integrations, and third-party filtering layers. These factors may either reduce or increase the practical exploitability of the tested scenarios. For example, a third-party gateway might block a message before it reaches Exchange Online, while an overly broad enterprise allowlist might create even more permissive behavior than the sandbox. The sandbox is valuable because it isolates specific mechanisms, but it cannot capture every operational detail of a real deployment.

The payload set was intentionally limited. The experiments used benign, spam, phishing, and EICAR-based malware categories with short and long variants. This design was sufficient to test whether allowlist rules changed delivery placement across broad content types, but it does not represent the full range of modern phishing techniques.

The domain analysis is also time-dependent. Domain registration status can change, and the set of domains used by vendors can evolve. A domain that is registered during measurement may expire later, while a domain not visible in public documentation may still be used internally or for customer-specific campaigns. The analysis therefore provides a snapshot rather than a permanent guarantee. Continuous monitoring would be required to make stronger claims about long-term domain safety.

Another limitation is that public documentation may not reflect the full infrastructure used by SAT providers. Vendors may supply customer-specific domains, private allowlisting instructions, regional infrastructure, or dedicated sending environments under contract. Because this study was conducted independently and without vendor partnership, it relied on publicly accessible documentation and available test infrastructure. This may underrepresent more secure enterprise-grade configurations, but it may also reflect what smaller organizations actually implement when following public setup guides.

Finally, the experiments do not claim that allowlisting is always unsafe. Some form of delivery accommodation may be necessary for realistic phishing simulations. The issue is not the existence of allowlisting, but its scope, authentication strength, and lifecycle management. A tightly scoped, temporary, monitored allowlist tied to strong sender identity is very different from a permanent tenant-wide bypass triggered by a spoofable header or broad shared IP range. The main contribution

of this thesis is to show why that distinction matters.

6.11 Future Work

Future work could extend this thesis in several directions. First, future studies could evaluate a wider range of SAT vendors and allowlisting configurations, including customer-specific sending domains, dedicated vendor infrastructure, and third-party secure email gateways. This would help determine whether the risks observed in the sandbox also appear across more diverse enterprise deployments.
Second, future work could examine additional phishing techniques that were outside the scope of this study. These could include credential-harvesting links, QR-code phishing, attachment formats other than EICAR, conversation hijacking, business email compromise templates, and payloads designed to evade link analysis. Such experiments would require careful ethical controls, but they would provide a more complete view of how different phishing styles interact with allowlist rules.
Third, future research could study the lifecycle management of SAT allowlists in real organizations. This could include measuring how often allowlist rules remain active after training campaigns, how frequently domains are reviewed, and whether administrators remove outdated vendor entries. Such work would help quantify the long-term operational risk created by stale or overly broad allowlist configurations.
Finally, future work could design and evaluate safer allowlisting mechanisms. Examples include campaign-scoped rules, automatically expiring mail-flow rules, sender identity checks based on aligned DKIM, and monitoring systems that alert when SAT bypass rules are triggered outside approved training windows. This would move beyond identifying the problem and toward building practical defenses that preserve the usefulness of phishing simulations without creating reusable trust paths for attackers.

7

Conclusion

This thesis investigated the security risks introduced by allowlisting configurations used to support SAT and simulated phishing campaigns. The central motivation was that phishing simulations must often bypass parts of an organization's email security stack in order to reach employee inboxes. While this is operationally necessary for training, the results show that these exceptions can also create exploitable trust paths if they are too broad, permanent, or based on weak indicators.

The experiments were conducted in a controlled Microsoft 365 sandbox and focused on common allowlisting mechanisms, including header-based transport rules, IP-based allowlisting of shared delivery infrastructure, and domain-based trust assumptions. Across the completed experimental phases, the results show that allowlisting can significantly change how emails are handled by the protection stack. In particular, non-malware payloads that contained spam-like or phishing-like content were delivered to the Inbox when they matched the tested allowlist conditions. At the same time, malware payloads using the EICAR test string continued to be quarantined. This means that the tested allowlists did not disable all security controls, but they did weaken spam and phishing filtering in a way that is relevant to real-world phishing risk.

The most important conclusion is that SAT allowlisting should be treated as a security-sensitive exception rather than a routine administrative setup step. A rule that allows simulated phishing emails to bypass filtering can also allow attacker-controlled messages to bypass filtering if the rule is based on spoofable or overly broad conditions. Therefore, the safety of a phishing simulation program depends not only on the quality of the training content, but also on the technical design of the allowlisting mechanism that makes the simulation possible.

7.1 Answers to the Research Questions

This section summarizes how each research question was addressed and how it was answered by the completed work. The answers should be interpreted within the scope of the experiments conducted in this thesis: a controlled Microsoft 365 sandbox, specific allowlist configurations, and the payload categories defined in the methodology. The results therefore demonstrate how the tested configurations behaved, but they should not be taken as universal claims about all enterprise email environments.

RQ1: Can an attacker bypass enterprise spam filters by spoofing standard simulation headers such as `X-PHISHTEST`?

The sandbox results showed that, in the tested Microsoft 365 configuration, a header-based transport rule using `X-PHISHTEST: true` was sufficient to move non-malware payloads into the Inbox. This included benign, spam-like, and phishing-like messages. Within the scope of the experiment, this demonstrates that a custom simulation header is not a reliable trust signal when used as the only allowlist condition.

The underlying reason is that such headers are part of the message content and can be inserted by any sender with control over the raw email. Unless the receiving system also verifies the sender's identity, the header only proves that the message contains a matching string—it does not prove that the message originated from the authorized SAT provider. Therefore, the answer to RQ1 is yes: **within the tested configuration, an attacker could bypass spam filtering for non-malware messages by spoofing the expected simulation header.**

However, this conclusion must be interpreted carefully. The result applies to the specific transport rule, sandbox tenant, and payload set used in this thesis. The bypass affected spam and phishing placement for non-malware messages, but it did not cause the tested malware payloads to reach the Inbox, as those were still quarantined. The header-spoofing attack therefore represents a significant phishing-delivery risk in the tested configuration, but not a complete bypass of all Microsoft Defender protection layers, nor a general claim about every enterprise email environment.

RQ2: Can an attacker utilize a trial account on a major SAT platform or shared sending provider to deliver malicious emails to organizations that have allowlisted that vendor's IP range?

The shared infrastructure experiment showed that both the authorized SendGrid account and an unrelated SendGrid account produced the same delivery outcome when the SendGrid IP range was allowlisted. Non-malware payloads from both accounts reached the Inbox, while malware payloads were quarantined.

This result confirms that IP-based allowlisting of shared cloud infrastructure grants trust at the infrastructure level rather than at the account or tenant level. If an organization allowlists a shared IP range because a trusted SAT vendor uses it, other senders using the same infrastructure may also inherit that trust. In the tested configuration, the receiving tenant did not distinguish between the expected sender and the unrelated sender once the IP allowlist condition was satisfied.

Therefore, the answer to RQ2 is yes: in the tested configuration, an unrelated sender using the same shared infrastructure could benefit from the allowlist. This finding supports the argument that shared IP ranges are too broad to serve as standalone trust anchors for phishing simulation delivery. Dedicated sending infrastructure or stronger sender identity checks should be preferred.

RQ3: What percentage of default phishing domains used by major SAT vendors are currently unregistered and vulnerable to takeover?

RQ3 was partially answered. The domain analysis reviewed domains associated with several major SAT vendors and did not identify unregistered domains among the primary domain sets examined. Based on the reviewed dataset, the observed percentage of unregistered domains was therefore zero.

This is a positive result because it suggests that the main domains reviewed for established vendors were registered and actively controlled at the time of analysis. However, the answer is only partial because domain registration status is time-dependent and the analysis was limited to publicly visible or documented domains. It cannot prove that all vendor domains, legacy domains, campaign-specific domains, or customer-specific domains are safe. It also cannot guarantee that currently registered domains will remain registered in the future.

Therefore, RQ3 was answered for the tested dataset, but not universally. The completed analysis found no immediately vulnerable unregistered domains in the reviewed primary vendor domain sets. Nevertheless, the broader risk of stale domain allowlists, expired campaign domains, outdated documentation, and domain lifecycle failures remains relevant.

RQ4: What technical strategies can minimize the attack surface created by SAT allowlist configurations while preserving the effectiveness of the training program?

RQ4 was answered through the interpretation of the experimental results and the mitigation strategies discussed in Chapter 6. The results show that safer SAT integration requires allowlisting to follow least-privilege principles.

The main technical strategies are as follows. Header-only rules should be avoided, because custom headers such as `X-PHISHTEST` are easily spoofed. If such headers are used, they should be combined with stronger identity checks, such as verified sender domains, aligned DKIM, known return-path domains, dedicated sending IP addresses, and campaign-specific recipient scopes. Shared IP allowlisting should be avoided where possible, because it may extend trust to unrelated tenants on the same infrastructure. Dedicated sending infrastructure or customer-specific sending domains provide a narrower and safer trust boundary.

Allowlists should also be temporary, monitored, and scoped to the training campaign. They should be enabled only during the campaign window, restricted to the intended recipients, and removed or disabled after the simulation ends. Security teams should log when allowlist rules are matched and alert on unexpected use, such as messages from unknown senders, outside approved campaign periods, or at unusual volumes. Domain-based allowlists should be reviewed periodically to remove stale entries and detect ownership or registration changes.

Therefore, RQ4 was answered by identifying a set of technical controls that reduce the attack surface while still allowing phishing simulations to function.

7.2 Final Remarks

The findings demonstrate that the security risk is not caused by SAT itself, but by how SAT traffic is integrated into enterprise email systems. Phishing simulations are valuable because they expose users to realistic attack scenarios in a controlled environment. However, to deliver those simulations, organizations often introduce exceptions into the same filtering systems that are designed to block real attacks. If these exceptions are too broad, attackers may be able to reuse them.

The experiments showed that the most problematic allowlist configurations are those based on weak or shared identifiers. A spoofable header does not authenticate the sender. A shared IP range does not uniquely identify a vendor or customer account. A domain allowlist can become stale if it is not reviewed over time. These mechanisms can be useful as part of a broader rule, but they should not be treated as sufficient proof that a message is authorized simulation traffic.

At the same time, the results also showed that some security layers remained effective. Malware payloads were quarantined across all completed phases, indicating that the tested bypasses did not fully disable the protection stack. The practical concern is more specific: broad SAT allowlists can allow phishing-like and spam-like messages to reach the Inbox, increasing reliance on users and downstream controls.

The overall conclusion is that SAT allowlisting must be designed with the same care as any other privileged security exception. Organizations should rely on precise sender identity, temporary campaign windows, limited recipient scope, continuous monitoring, and regular review. Vendors should support safer deployment models by discouraging header-only and shared-IP allowlisting and by providing customer-specific, authenticated delivery mechanisms.

In summary, this thesis shows that allowlisting for phishing awareness training can introduce measurable security weaknesses when implemented without sufficient constraints. The safest approach is not to abandon phishing simulations, but to ensure that the mechanisms used to deliver them do not create a reusable path for real attackers.

Bibliography

[1] Hong, J. (2012). *The State of Phishing Attacks*. Communications of the ACM, 55(1), 74–81. ACM.

[2] Kumaraguru, P., Rhee, Y., Acquisti, A., Cranor, L. F., Hong, J., & Nunge, E. (2007). *Protecting People from Phishing: The Design and Evaluation of an Embedded Training Email System*. Proceedings of the SIGCHI Conference on Human Factors in Computing Systems, 905–914. ACM.

[3] Verma, P., Goyal, A., & Gigras, Y. (2020). *Email phishing: text classification using natural language processing*. Computer Science and Information Technologies.

[4] Eye Security. (2023). *How Microsoft might have lured unsuspecting end-users into the hands of criminals*. Eye Security Research Blog.

[5] Wright, J., & contributors. (2016). *Gophish: Open-Source Phishing Framework*. Retrieved from https://getgophish.com/

[6] Klensin, J. (2008). *Simple Mail Transfer Protocol*. RFC 5321. RFC Editor. https://doi.org/10.17487/RFC5321

[7] Microsoft. (2025). *Order and Precedence of Email Protection in Microsoft Defender for Office 365*. Microsoft Learn.

[8] KnowBe4. (2026). *KnowBe4 Security Awareness Training Platform*. KnowBe4 Knowledge Base. Retrieved from https://support.knowbe4.com/

[9] Cofense. (2026). *Cofense PhishMe: Phishing Simulation and Awareness Training*. Cofense Product Documentation. Retrieved from https://cofense.com/

[10] Proofpoint. (2026). *Proofpoint Security Awareness Training Platform*. Proofpoint Solution Documentation. Retrieved from https://www.proofpoint.com/

[11] Microsoft. (2026). *Attack Simulation Training in Microsoft Defender for Office 365*. Microsoft Learn. Retrieved from https://learn.microsoft.com/en-us/defender-office-365/attack-simulation-training-get-started

[12] CastleRock. (2023). *Sky Risks: The Dangers of Email Allowlisting*. CastleRock IT Security Blog.

[13] Dhamija, R., Tygar, J. D., & Hearst, M. (2006). *Why Phishing Works*. Proceedings of the SIGCHI Conference on Human Factors in Computing Systems, 581–590. ACM.

[14] Ho, G., Mirian, A., Luo, E., Tong, K., Lee, E., Liu, L., Longhurst, C. A., Dameff, C., Savage, S., & Voelker, G. M. (2025). *Understanding the Efficacy of Phishing Training in Practice*. 2025 IEEE Symposium on Security and Privacy (SP). IEEE.

[15] Toth, R., Dubniczky, R. A., Limonova, O., & Tihanyi, N. (2025). *Sustaining Cyber Awareness: The Long-Term Impact of Continuous Phishing Training and Emotional Triggers*. arXiv.

[16] Chen, J., Paxson, V., & Jiang, J. (2020). *Composition Kills: A Case Study of Email Sender Authentication*. USENIX Security Symposium, 2183–2199. USENIX Association.

[17] Shen, K., Wang, C., Guo, M., Zheng, X., Lu, C., Liu, B., Zhao, Y., Hao, S., Duan, H., Pan, Q., & Yang, M. (2021). *Weak Links in Authentication Chains: A Large-scale Analysis of Email Sender Spoofing Attacks*. 30th USENIX Security Symposium, 3201–3217. USENIX Association.

[18] Wang, C., Kuranaga, Y., Wang, Y., Zhang, M., Zheng, L., Li, X., Chen, J., Duan, H., Lin, Y., & Pan, Q. (2024). *BreakSPF: How Shared Infrastructures Magnify SPF Vulnerabilities Across the Internet*. Network and Distributed System Security Symposium. Internet Society.

[19] Zhang, Y., & Lin, Z. (2022). *When Good Becomes Evil*. CCS '22.

[20] Wood, T., et al. (2021). *Systematic Literature Review: Anti-Phishing Defences and Their Application to Before-the-click Phishing Email Detection*. Journal of Information Security and Applications.

DEPARTMENT OF SOME SUBJECT OR TECHNOLOGY
CHALMERS UNIVERSITY OF TECHNOLOGY
Gothenburg, Sweden
www.chalmers.se



CHALMERS
UNIVERSITY OF TECHNOLOGY